



DEBRETABOR UNIVERSITY
FACULTY OF TECHNOLOGY
DEPARTMENT OF COMPUTER SCIENCE

A Module for The Course Computer Security (BSc.)

Prepared by:
Genet W. and Huluager W.

January 15, 2022
Debre Tabor, Ethiopia

Chapter One.....	1
1. Introduction to computer security.....	1
1.1. Basic concepts of computer security.....	1
1.2. Threats, vulnerabilities, controls, risk.....	3
1.3. Goals of computer security.....	4
1.4. Security attack.....	5
1.5. Security policies and mechanisms.....	8
1.6. Prevention, detection, and deterrence.....	9
1.7. Software security assurance.....	10
Chapter Two.....	12
2. Computer Threat.....	12
2.1. Malicious code.....	12
2.1.1. Viruses.....	12
2.1.2. Trojan horses.....	13
2.1.3. Worms.....	13
2.1.4. Spy-wares.....	13
2.2. Class of Attacks.....	13
2.2.1. Reconnaissance attacks.....	13
2.2.2. Access attacks.....	14
2.2.3. Denial of Service attacks.....	15
2.3. Program flaws.....	16
2.3.1. Buffer overflows.....	16
2.3.2. Time-of-check to time-of-use flaws.....	17
2.3.3. Incomplete mediation.....	17
2.3.4. Controls to protect against program flaws in execution.....	18
2.3.5. Operating system support and administrative controls.....	18
2.3.6. Software development controls and Testing techniques.....	19
2.3.7. Database management systems security.....	19
Chapter Three.....	21
3. Cryptography and Encryption Techniques.....	21
3.1. Basic cryptographic term.....	21
3.2. Historical background.....	21
3.3. Cipher Techniques.....	22
3.3.1. Transposition Cipher.....	22
3.3.2. Substitution Cipher.....	22
3.4. Conventional encryption algorithms.....	22
3.5. Cryptanalysis.....	23
3.6. Cryptographic Systems.....	23
3.6.1. Symmetric key cryptography.....	24
3.6.1.1. DES (Data Encryption Standard).....	24

3.6.1.2. 3DES (triple DES).....	25
3.6.1.3. AES (Advanced Encryption Standard).....	25
3.6.1.4. Block Cipher Modes.....	28
3.6.2. Public key cryptography.....	32
3.6.2.1. Diffie-Hellman (DH)algorithm.....	37
3.6.2.2. RSA Algorithm.....	38
3.6.3. Digital Signature.....	40
3.6.4. Public key Infrastructure (PKI).....	41
Chapter Four.....	47
4. Network Security.....	47
4.1. Threats on network.....	47
4.2. Trust, Weaknesses, Risk and Vulnerabilities.....	50
4.3. TCP/IP Suit Weaknesses and Buffer Overflows.....	52
4.4. Network security protocols.....	52
4.5. Application layer security.....	54
4.6. Wireless Security.....	54
Chapter Five.....	56
5. Security Mechanisms.....	56
5.1. Firewall.....	56
5.2. Proxy server.....	57
5.3. IDS/IPS.....	61
5.4. Virtual Private network.....	62
Chapter Six.....	64
6. Authentication and Access control.....	64
6.1. Authentication basics	64
6.1.1. Password and passphrase.....	64
6.1.2. Biometrics	64
6.1.3. AAA server.....	65
6.1.4. Smart cards and memory cards.....	66
6.2. Access control basics.....	66
6.3. Access control models.....	67
6.3.1. The Mandatory Access Control.....	67
6.3.2. The Discretionary Access Control, or DAC.....	67
6.3.3. Rule-Based Access Control.....	67
Chapter seven.....	68
7.1 Security planning	68
7.2 Risk analysis.....	68
7.3 Security policies.....	70

7.4 Cyber security	71
--------------------------	----

Chapter One

1. Introduction to computer security

1.1. Basic concepts of computer security

Computer Security is the process of detecting and preventing any unauthorized use of your laptop/computer. It involves the process of safeguarding against trespassers from using your personal or office-based computer resources with malicious intent or for their own gains, or even for gaining any access to them accidentally. The terms Computer security, network security and information security are often used interchangeably. Network security is generally taken as providing protection at the boundaries of an organization by keeping out intruders or hackers. Network security starts from authenticating the user, commonly with a username and a password. Once authenticated, a firewall enforces access policies such as what services are allowed to be accessed by the network users. Information security, however, explicitly focuses on protecting data resources from malware attack or simple mistakes by people within an organization by use of data loss prevention (DLP) techniques. **DLP techniques** are used to identify sensitive data (in motion, at rest, or in use). Care has to be taken to ensure the accuracy of the **DLP** technology is high enough to ensure lower rates *of false-positive reporting.

Computer security is the protection of the items you value, called the assets of a computer or computer system. There are many types of assets, involving hardware, software, data, people, processes, or combinations of these. To determine what to protect, we must first identify what has value and to whom.

Cyberspace (internet, work environment, intranet) is becoming a dangerous place for all organizations and individuals to protect their sensitive data or reputation. This is because of the numerous people and machines accessing it. It is important to mention that the recent studies have shown a big danger is coming from internal threats or from disappointed employees like the *Edward Snowden case*, another internal threat is that information material can be easily accessible over the intranet.

One important indicator is the IT skills of a person that wants to hack or to breach your security has decreased but the success rate of it has increased, this is because of three main factors –

- Hacking tools that can be found very easily by everyone just by googling and they are endless.
- Technology with the end-users has increased rapidly within these years, like internet bandwidth and computer processing speeds.
- Access to hacking information manuals.

All this can make even a school boy with the curiosity, a potential hacker for your organization.

Since locking down all networks is not an available option, the only response the security managers can give is to harden their networks, applications and operating systems to a reasonable level of safety, and conducting a business disaster recovery plan.

What to secure?

- First of all, is to check the physical security by setting control systems like motion alarms, door accessing systems, humidity sensors, temperature sensors. All these components decrease the possibility of a computer to be stolen or damaged by humans and environment itself.
- People having access to computer systems should have their own user id with password protection.
- Monitors should be screen saver protected to hide the information from being displayed when the user is away or inactive.
- Secure your network especially wireless, passwords should be used.
- Internet equipment as routers to be protected with password.
- Data that you use to store information which can be financial, or non-financial by encryption.
- Information should be protected in all types of its representation in transmission by encrypting it.

1.2. Threats, vulnerabilities, controls, risk

Threats

Most organizations take action against credible threats before they happen. Natural threats can be planned for by understanding what has happened before. An example would be floods, tornados, or earthquakes. Threat actors, on the other hand, aiming to destroy data and disrupt operations are two of the leading fears that organizations try to defend against first. Security programs are purpose-built to address security threats by defending against “what if” scenarios. A good example of potential threats involves malware, ransomware, and viruses. Attackers often focus on the total destruction of an asset, Distributed Denial of Services (DDoS), or social engineering to accomplish their goals.

vulnerabilities

Vulnerabilities exist in systems, regardless of make, model, or version. The term vulnerability exposes potential weak points in hardware and software. In applications, the vulnerability can often be patched by the manufacturer to harden and prevent exploitation of the weakness. Unauthorized access can be an example of someone taking advantage of a vulnerability. The system should only allow authorized access and if someone unauthorized is granted access, it violates IT security and bypasses access controls.

Risk

When it comes to risks, organizations are looking at what may cause potential harm to systems and the overall business. Several examples of systems susceptible to IT risk include phishing attacks, operating systems, and sensitive data. Organizations go to great lengths to mitigate, transfer, accept, and avoid risks. A risk assessment is often the first line of defense to reduce security risk. In order to better prepare for the inevitability of risks, assessments are necessary to baseline an attack surface. Organizations should invest in a risk management program to better understand how to measure risk.

Controls

Information security controls are measures taken to reduce information security risks such as information systems breaches, data theft, and unauthorized changes to digital information or systems. These security controls are intended to help protect the availability, confidentiality, and

integrity of data and networks, and are typically implemented after an information security risk assessment.

Security controls come in the form of:

Access controls including restrictions on physical access such as security guards at building entrances, locks, and perimeter fences.

- **Procedural controls** such as security awareness education, security framework compliance training, and incident response plans and procedures
- **Technical controls** such as multi-factor user authentication at login (login) and logical access controls, antivirus software, firewalls

Compliance controls such as privacy laws and cyber security frameworks and standards

1.3.Goals of computer security

Computer security has three main goals, confidentiality, availability and integrity.

Confidentiality:

Confidentiality prevents the disclosure of sensitive information to unauthorized users or systems on computer networks. Sensitive information refers to the information that should be kept confidential. Loss of confidentiality leads to the unauthorized disclosure of sensitive information. In literature, confidentiality is used to provide data confidentiality and privacy. Data confidentiality prevents unauthorized entities from accessing confidential information whereas privacy ensures entities can control or influence information related to them. Data confidentiality assures that confidential data or information is not made available to unauthorized entities in the system.

Integrity

In computer networks and systems, the term integrity covers both data and systems. Generally, integrity assures the accuracy and consistency of data and systems, which means guarding against improper modification or destruction of data and systems in an unauthorized or undetected manner. A loss of integrity is the unauthorized change or destruction of data or systems.

Data integrity assures that data are modified only in a specified and authorized manner on computer networks and systems. For instance, assume that electronic health records (EHRs) are

stored in a centralized repository and many organizations are able to access EHRs via the Internet. Hospitals and medical insurance companies are some of the organizations related to these data. In this case, unauthorized access with write permission disrupts the integrity of EHRs that may result in financial losses and health problems for patients.

System integrity assures that a system performs its intended functions in a continuous manner, free from deliberate or inadvertent unauthorized modification of the computer network or system.

Availability

The availability objective ensures that computer networks and systems work properly and services are accessible and are not denied for authorized users. Specifically, availability ensures timely and reliable access to information and services on computer networks and systems. A loss of availability leads to the disruption of access to the information and services on the systems.

Availability is the most important security service for some services on computer networks and systems. Highly available systems or services remain available at all times.

1.4. Security attack

A security attack is an unauthorized attempt to steal, damage, or expose data from an information system such as your website. We can classify security attacks as passive and active attacks.

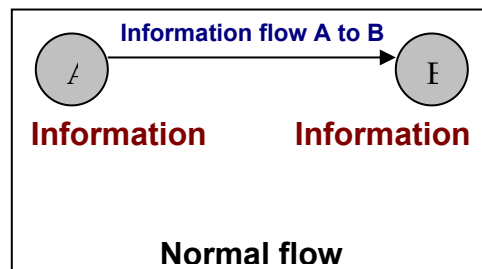
Passive attacks: A passive attack attempts to learn or make use of information from the system but does not affect the system resources. The passive attackers are in the nature of eavesdropping on, or monitoring of transmissions with a goal of obtaining information being transmitted. The passive attacks are very difficult to detect because they do not involve any alteration of data. Measures are available to prevent their success. Two types of passive attacks are: - release of message content and traffic analysis.

- **Release of message content:** The process of preventing an opponent from learning the contents of transmissions
- **Traffic analysis:** The process of guessing the information being transmitted by observing the frequency and length of message being exchanged.

Active attack: Active attacks attempts to alter system resources or affects their operation. It is very difficult to prevent active attacks absolutely.

Classification of active attacks/threats:

According to sources, attacks on the security of a computer can be characterized best by viewing how the computer functions when sending and receiving information. The normal and accurate flow of information from one source (Source A) to another source, which is the destination (B), is shown in the diagram below:



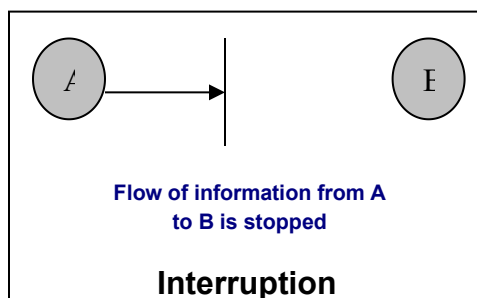
However, deviations from the normal flow of information will happen if there is an attack or a threat:

These threats can be classified as:

- Interruption
- Interception
- Modification
- Fabrication

Interruption:

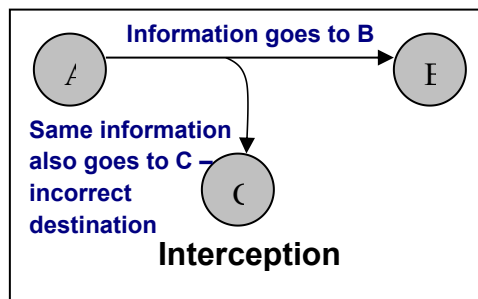
- This happens when an asset is destroyed or becomes unavailable or cannot be used. This is an attack on the availability of the system. Diagram (b) shows how interruption can occur.



Examples of **interruption** are destruction of a piece of hardware, the cutting of cable and disabling of a file management system.

Interception:

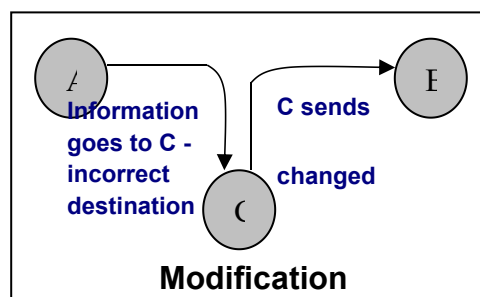
Interception occurs when any unauthorized unit gains access to an asset. This attack means that there is no privacy therefore it is an attack on confidentiality. The unauthorized unit or party could be an individual, a program or even another computer. Diagram (c) reveals the nature of interception.



Examples of **interception** can be seen in wiretapping to capture data into a network and copying of files which is not permitted.

Modification:

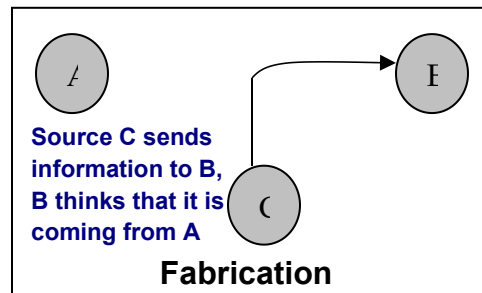
If an unauthorized party gains access to a system and make some changes to it, then this tampering is known as Modification. This medication is an attack on the integrity of the system or the organization. Diagram (d) depicts this attack.



Examples of such tampering includes the changing of values in a file, altering a program so that it performs differently and changing the contents of messages that are sent over the network.

Fabrication:

If an unauthorized party gains access to the system and inserts false objects into it, this is Fabrication and it degrades the authenticity of the system. Diagram (e) reflects this information.



Examples: of such an attack include a hacker gaining access to a person's email and sending messages. This makes the recipients believe that it is indeed the person sending the message when it is in fact not so **OR** it could be addition of records to a file.

1.5.Security policies and mechanisms

A **security policy** is a statement of what is, and what is not, allowed. policies may be presented mathematically, as a list of allowed (secure) and disallowed (nonsecure) states. For our purposes, we will assume that any given policy provides an axiomatic description of secure states and nonsecure states.

A **security mechanism** is a method, tool, or procedure for enforcing a security policy. A mechanism that is designed to detect, prevent or recover the system from the security attacks. The security mechanisms are as follow.

- **Decipherment:** The use of mathematical algorithms to transfer the data into a form that is not readily intelligible.
- **Digital signatures:** Used to protect the data against forgery. Digital signature appended to the data unit that allows a recipient of the data unit to prove the source and integrity of the data unit.
- **Access Control:** These mechanisms enforce access rights to resources.
- **Data integrity:** A variety of mechanisms are used to assure the integrity of data unit.
- **Authentication exchange:** A mechanism intended to ensure the identity of an entity by means of information exchange.
- **Traffic padding:** The insertion of bits into gaps in a data stream to control traffic analysis attacks

- **Notarization:** The use of trusted third party to assure certain properties of a data exchange.
- **Routing control:** Enables selection of particular physically secure routes for certain data and allows routing changes.

1.6. Prevention, detection, and deterrence

Prevention:

Information security professionals must continuously mature their capabilities by working smarter not harder. It is always better to prevent, then to pursue and prosecute. Preventing an incident requires careful analysis and planning. Information is an asset that requires protection commensurate with its value.

Security measures must be taken to protect information from unauthorized modification, destruction, or disclosure whether accidental or intentional. During the prevention phase, security policies, controls and processes should be designed and implemented. Security policies, security awareness programs and access control procedures, are all interrelated and should be developed early on. The information security policy is the cornerstone from which all else is built.

Detection:

Detection of a system compromise is extremely critical. With the ever-increasing threat environment, no matter what level of protection a system may have, it will get compromised given a greater level of motivation and skill. There is no full proof “silver bullet” security solution. A defense in layers strategy should be deployed so when each layer fails, it fails safely to a known state and sounds an alarm. The most important element of this strategy is timely detection and notification of a compromise. **Intrusion detection systems (IDS)** are utilized for this purpose.

IDS have the capability of monitoring system activity and notifies responsible persons when activities warrant investigation. The systems can detect attack signatures and also changes in files, configurations and activity. To be protected, the entire system should be monitored. Intrusion detection tools should be strategically placed at the network and application levels. However, monitoring a busy network or host is not a simple task. Intrusion detection tools must

have the ability to distinguish normal system activity from malicious activity. This is more of an art than a science. The IDS must be fine-tuned or “tweaked” in order for the IDS to work in accord with a particular network or host. This tuning process must take into account known threats, as well as intruder

1.7. Software security assurance

The Software Security Assurance (SSA) is a process that helps design and implement software that protects the data and resources contained in and controlled by that software. Software is itself a resource and thus must be afforded appropriate security.

The SSA team focuses on addressing security in the early life-cycle phases of acquisition and software development. Building security into software requires considerations beyond basic authentication/authorization and mandated operational compliance to identify and address the threat environment in which the resulting operational system must function. With greater security preparation, organizations have seen major reductions in operational vulnerabilities resulting in reductions in software patching.

What causes software security problems?

All security vulnerabilities in software are the result of security bugs, or defects, within the software. In most cases, these defects are created by two primary causes:

- a) **Non-conformance, or a failure to satisfy requirements:** it may be simple and the most common is a coding error or defect—or more complex (i.e., a subtle timing error or input validation error). The important point about non-conformance is that verification and validation techniques are designed to detect them and security assurance techniques are designed to prevent them. Improvements in these methods, through a software security assurance program, can improve the security of software.
- b) **An error or omission in the software requirements:** The most serious security problems with software-based systems are those that develop when the software requirements are incorrect, inappropriate, or incomplete for the system situation. Unfortunately, errors or omissions in requirements are more difficult to identify. For example, the software may perform exactly as required under normal use, but the requirements may not correctly deal with some system state. When the system enters this problem state, unexpected and

undesirable behavior may result. This type of problem cannot be handled within the software discipline; it results from a failure of the system and software engineering processes which developed and allocated the system requirements to the software.

Software security assurance activities

There are two basic types of Software Security Assurance activities.

1. Some focus on ensuring that information processed by an information system is assigned a proper sensitivity category, and that the appropriate protection requirements have been developed and met in the system.
2. Others focus on ensuring the control and protection of the software, as well as that of the software support tools and data.

Chapter Two

2. Computer Threat

A computer system threat in general can include anything deliberate, unintended, or caused by natural calamity that effects in data loss/manipulation or physical destruction of hardware. Accordingly, the threats on computer system are classified as **physical** threats and **nonphysical** threats. Physical threats cause impairment to hardware or theft to system or hard disk that holds critical data. Nonphysical threats target the data and the software on the computer systems by corrupting the data or by exploiting the errors in the software.

2.1.Malicious code

Malicious code is harmful computer programming scripts designed to create or exploit system vulnerabilities. This code is designed by a threat actor to cause unwanted changes, damage, or ongoing access to computer systems. Malicious code may result in back doors, security breaches, information and data theft, and other potential damages to files and computing systems. And it is the language hostile parties “speak” to manipulate computer systems into dangerous behaviors. It is created by writing changes or add-ons to the existing programming of computer programs, files, and infrastructure. Many malicious code types can harm your computer by finding entry points that lead to your precious data. Among the ever-growing list, here are some common culprits.

2.1.1. Viruses

Viruses are self-replicating malicious code that attaches to macro-enabled programs to execute. These files travel via documents and other file downloads, allowing the virus to infiltrate your device. Once the virus executes, it can self-propagate and spread through the system and connected networks.

Following are a couple of characteristics of any virus that infects our computers.

- They reside in a computer’s memory and activates themselves while the program that is attached starts running.
 - **For example** – They attach themselves in general to the **explorer.exe** in windows OS because it is the process that is running all the time, so you should

be cautious when this process starts to consume too much of your computer capacities.

- They modify themselves after the infection phase like they source codes, extensions, new files, etc. so it is harder for an antivirus to detect them.
- They always try to hide themselves in the operating systems in the following ways
 - Encrypts itself into cryptic symbols, and they decrypt themselves when they replicate or execute.

2.1.2. Trojan horses

Trojans are decoy files that carry malicious code payloads, requiring a user to use the file or program to execute. These threats cannot self-replicate or spread autonomously. However, their malicious payload could contain viruses, worms, or any other code.

2.1.3. Worms

Worms are also self-replicating and self-spreading code like viruses but do not require any further action to do so. Once a computer worm has arrived on your device, these malicious threats can execute entirely on their own without any assistance from a user-run program.

2.1.4. Spy-wares

Spyware is a type of malicious software or malware that is installed on a computing device without the end user's knowledge. It invades the device, steals sensitive information and internet usage data, and relays it to advertisers, data firms or external users. Any software can be classified as spyware if it is downloaded without the user's authorization. Spyware is controversial because, even when it is installed for relatively innocuous reasons, it can violate the end user's privacy and has the potential to be abused.

2.2. Class of Attacks

There are three classes of attack that are commonly found in today's network environment: Reconnaissance attacks, Access attacks and Denial of service (DoS) attacks.

2.2.1. Reconnaissance attacks

Reconnaissance attacks are general knowledge gathering attacks. These attacks can happen in both logical and physical approaches. Whether the information is gathered via probing the network or through social engineering and physical surveillance, these attacks can be preventable

as well. Some common examples of reconnaissance attacks include **packet sniffing, ping sweeping, port scanning, phishing, social engineering** and **internet information queries**. We can examine these further by breaking them into the two categories of logical and physical.

Logical Reconnaissance refers to anything that is done in the digital spectrum and doesn't require a human on the other side to complete the reconnaissance attack. Ping sweeps and port scans, for example, are two methods of discovering both if the system is there and what it is looking for on the network.

Physical Reconnaissance: it crosses the lines of what a network admin has control of. There are elements that will never be protected fully like locations as well as security elements like cameras, mantraps, door locks or guards. However, these can play into physically securing a network.

For example, bank security may be limited in the ability to stop an extremely well-orchestrated heist attempt to what that security team has prepared for, but the simple fact that a bank has security in place creates the potential to deter most lower to mid-level criminals who would make the attempt. That is the same idea that goes into most physical security measures for network protection. Reconnaissance, as we have established, is the collection of information from any available sources. If the surveyor cannot access the information easily, it can deter the collection altogether or force them into a more logical realm.

Solution:

Try to limit the information posted about a company's contact information. Edit banner returns for banner-grabbing attacks so the information is limited to the attacker. If all the information for contacting the network admin or company representative is required, be sure those personnel are trained up on how to spot social engineering attacks. This training needs to be extended out to all employees, as anyone is a risk of sharing company secrets if a social engineer is charismatic enough.

2.2.2. Access attacks

Access attacks require some sort of intrusion capability. These can consist of anything as simple as gaining an account holder's credentials to plugging foreign hardware directly into the network infrastructure. The sophistication of these attacks ranges just as far. Often these access attacks

can be compared to reconnaissance in being either logical or physical, logical being over the net and physical usually leaning more towards social engineering.

Logical access: attacks like exploitation through brute force attacks or testing passwords on the net by rainbow tables or dictionary attacks tend to create a ton of traffic on the network and can be easily spotted by even a lower experienced level network monitor. It is for this reason that most of the logical access attacks are usually put forward after enough reconnaissance or credentials have been obtained. There is also a tendency to lean on the passive side of attacking like man in the middle attacks to try to gather more information before becoming overly suspicious.

Physical access: is really either access to the hardware or access to the people. Social engineering is very dangerous and hard to defend against simply because your users are usually the weakest link in cybersecurity. The easiest type of social engineering attack involves sending out phishing emails designed to hook someone that way or getting a key logger on a person inside's computer to gain credentials that may escalate privileges of the attacker.

Solution:

This type of attack really comes down to network hardening. Most companies are limited to the capabilities of their equipment, so if your Cisco router is vulnerable to attack, then the best course of action is to know that attack, look for it and set rules on your network IDS/IPS for it. Update often and regularly.

2.2.3. Denial of Service attacks

Denial of service: means that the network cannot move traffic in any capacity. This can happen from power failure or flooding the network with junk traffic that clogs the network's ability to function. Both historically have happened without any malicious intent, and both can be prevented with physical and logical blockers.

To achieve a denial of service against an entire network, the attacker usually needs ample computer power on their end as well and often achieves this from a comparable network of devices that may or may not know they are involved. This would be referred to as a botnet, and it can bring swift devastation to a network without any warning through a process called the

distributed denial of service. Essentially, the linked computers all fire off packets into the network simultaneously.

A computing resource may seem superior to humankind, but like us, a computer can only perform one action at a time, so flooding the network with these packets generates a need to respond, and if the network cannot keep up with the responses, then the network simply cannot function. Another type of denial-of-service attack would be a crash to the system. This system crash can cause temporary or permanent damage to a network.

Solution

DoS and DDoS attack defense walk in parallel with access attack defense ideology. Protecting against these attacks can include a few options from maximizing bandwidth allocation to network isolation based on traffic types.

2.3. Program flaws

A term flaw used to describe a problem that exists in a software program. A **flaw** is a security risk, cause the program to crash, or cause other issues. Programmers are not ‘robots’ but human beings who occasionally commit mistakes unintentionally. Some of these mistakes do cause any damage to the program e.g., spelling mistakes. However, there are certain mistakes if went unnoticed can cause serious negative implications on the program. Three such common non-malicious programming errors are: Buffer overflows, Time-of-check and incomplete mediation.

2.3.1. Buffer overflows

- A buffer-overflow occurs when a memory reference which is beyond the declared boundary occurs. When an array/ string is declared, a finite memory is reserved for that variable. E.g., `int arr [5]` will reserve five memory slots.
- When a reference like `‘arr [5] =22;’` the subscript is out of bounds.
- Some compiler checks for such errors while some don’t (e.g., C compiler).
- Now, for those which don’t check such errors, the question arises as to Where ‘22’ went since no “Buffer Overflow” error happens.
- The answer to that lies as to what is adjacent to `arr [4]` (the last element of array). The number ‘22’ will be written in adjacent block of `arr [4]`. If that location contained any user’ data- that data will be over-written.

- If at the same spot any program is located (system or user), an attacker can create a fake overflow and place his own software(code) at that location next to arr [4].
- In such manner, an attacker can gain privileges or full control of the OS.

2.3.2. Time-of-check to time-of-use flaws

This is a race condition that often occurs between the time a whole or part of the system gets checked and the time it starts to be used. Programs that are shared by multiple processes are vulnerable to these kinds of flaws. Unix systems are more exposed to TOCTOU (time-of-check to time-of-use) bugs.

Consider the following example code for Unix systems: The **victim** code does two things: *checks* the if statement and then opens a file or *use* it. An **attacker**, on the other hand, can run a *symlink* (symbolic link) function to make the file point to a password database after the victim checks the

Victim	Attacker
<pre> if (access("file", W_OK) != 0) { exit(1); } fd = open("file", O_WRONLY); // Actually writing over /etc/passwd write(fd, buffer, sizeof(buffer)); </pre>	<pre> // // // After the access check symlink("/etc/passwd", "file"); // Before the open, "file" points to the password database // // </pre>

condition. Then, we victim starts writing, they actually write to the password file.

2.3.3. Incomplete mediation

Mediation means checking: the process of intervening to confirm an actor's authorization before it takes an intended action. Verifying that the subject is authorized to perform the operation on an object is called *mediation*. Incomplete mediation is a security problem that has been with us for decades: Forgetting to ask "Who goes there?" before allowing the knight across the castle drawbridge is just asking for trouble. In the same way, attackers exploit incomplete mediation to cause security problems.

Consider the following URL. In addition to a web address, it contains two parameters, so you can think of it as input to a program:

<http://www.somesite.com/subpage/userinput.asp?>

parm1=(808)555-1212&**parm2**=2015Jan17

As a security professional trying to find and fix problems before they occur, you might examine the various parts of the URL to determine what they mean and how they might be exploited. For instance, the parameters parm1 and parm2 look like a telephone number and a date, respectively. Probably the client's (user's) web browser enters those two values in their specified format for easy processing on the server's side. But what would happen if parm2 were submitted as 1800Jan01? Or 1800Feb30? Or 2048Min32? Or 1Aardvark2Many? Something in the program or the system with which it communicates would likely fail.

2.3.4. Controls to protect against program flaws in execution

The following are the major controls that need to be taken to control program flaws in the execution.

- Proper input validation
- Preserve Operating System command structure
- Properly handling race conditions in a program
- Constraining operations within the boundaries of a memory buffer.
- Protecting external control of file name, path, and data.
- Effectively controlling code generation also known as code injection
- Properly initialization of variables in a program
- Applying proper error handling in a program

Beyond these, programmers should also put into consideration the following countermeasures to ensure program flaws.

- Apply software engineering techniques
- Use Information hiding and encapsulation
- Apply Modularity
- Use Mutual suspicion
- Ensure confinement

2.3.5. Operating system support and administrative controls

All operating systems must protect themselves from security breaches, such as runaway processes (denial of service), memory-access violations, stack overflow violations, the launching of programs with excessive privileges, and many others. In addition to these, administrative tools can also be leveraged to enhance security of your environment/system.

2.3.6. Software development controls and Testing techniques

The goal of utilizing numerous testing methodologies in your software development process is to make sure your software can successfully operate in multiple environments and across different platforms. These can typically be broken down between functional and non-functional testing. Functional testing methods are usually conducted in order and include:

- Unit testing
- Integration testing
- System testing
- Acceptance testing

Non-functional testing methods incorporate all test types focused on the operational aspects of a piece of software. These include:

- Performance testing
- Security testing
- Usability testing
- Compatibility testing

The goal of security testing is to purposefully find loopholes and security risks in the system that could result in unauthorized access to or the loss of information by probing the application for weaknesses. There are multiple types of this testing method, each of which aimed at verifying six basic principles of security:

1. Integrity
2. Confidentiality
3. Authentication
4. Authorization
5. Availability
6. Non-repudiation

2.3.7. Database management systems security

Proprietary and corporate databases always contain sensitive information that must be protected from vulnerabilities and exploits. All companies need to work on a regular basis to identify existing and potential database security vulnerabilities and do everything possible to remediate those. Another major threat is the fact that database administrators are usually too slow to install critical security patches for databases. The following are some of the threats related to databases:

- Default or weak passwords
- SQL injection
- Excessive user and group privileges
- Unnecessary DBMS features enabled
- Broken configuration management
- Buffer overflows
- Privilege escalation
- Denial of service
- Un-patched RDBMS

Chapter Three

3. Cryptography and Encryption Techniques

3.1. Basic cryptographic term

Definition: Cryptography is associated with the process of converting ordinary plain text into unintelligible text and vice-versa. It is a method of storing and transmitting data in a particular form so that only those for whom it is intended can read and process it. Cryptography not only protects data from theft or alteration, but can also be used for user authentication.

Basic terminologies:

Plaintext-text that is not computationally tagged, specially formatted, or written in code.

Encryption-It is the process of encoding a message or information in such a way that only authorized parties can access it. Encryption does not itself prevent interference, but denies the intelligible content to a would-be interceptor.

Cyphertext-It is the encrypted text. Plaintext is what you have before encryption, and ciphertext is the encrypted result. The term cipher is sometimes used as a synonym for ciphertext, but it more properly means the method of encryption rather than the result.

Decryption-Decryption is the process of taking encoded or encrypted text or other data and converting it back into text that you or the computer can read and understand.

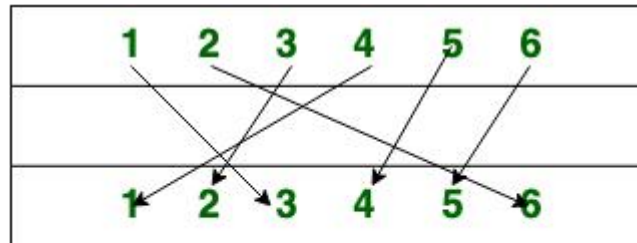
3.2. Historical background

Encryption or cryptography which means secret writing, is probably the strongest defense in the arsenal of computer security protection. Well disguised data cannot easily be read, modified, or fabricated. Simply put, encryption is like a machine: you put data into one end, gears spin and lights flash, you receive modified data out in the other end. In fact, some encryption devices used during the World War II operated with actual gears and rotors and these devices were effective in deterring the opposite side from reading the protected messages. Now the machinery has been replaced by computer algorithms but, the principle is the same. A transformation makes data difficult for an outsider to interrupt.

3.3. Cipher Techniques

3.3.1. Transposition Cipher

Transposition Cipher Technique rearranges the position of the plain text's characters. In transposition Cipher Technique, the position of the character is changed but character's identity is not changed. Example Rail Fence Cipher.



Transportation Cipher

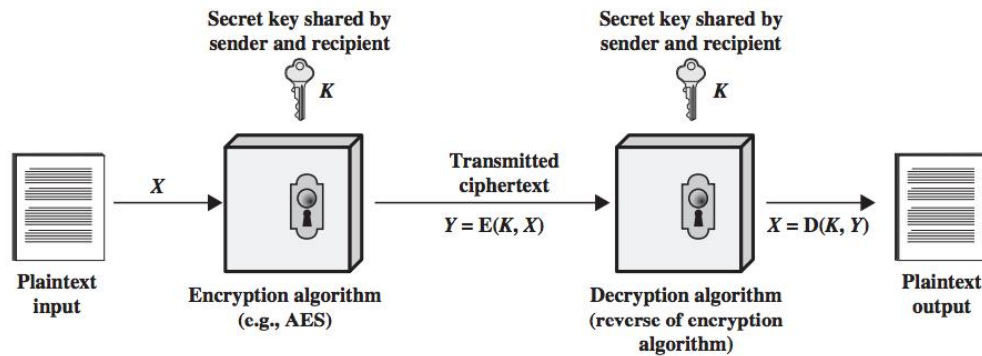
3.3.2. Substitution Cipher

In Substitution Cipher Technique plain text characters are replaced with other characters, numbers and symbols as well as in substitution Cipher Technique, character's identity is changed while its position remains unchanged. Example Caesar Cipher

3.4. Conventional encryption algorithms

Conventional encryption is a cryptographic system that uses the same key used by the sender to encrypt the message and by the receiver to decrypt the message. It was the only type of encryption in use prior to the development of public-key encryption. Conventional encryption has mainly 5 ingredients:

1. **Plain text** – It is the original data that is given to the algorithm as an input.
2. **Encryption algorithm** – This encryption algorithm performs various transformations on plain text to convert it into ciphertext.
3. **Secret key** – The secret key is also an input to the algorithm. The encryption algorithm will produce different outputs based on the keys used at that time.
4. **Ciphertext** – It contains encrypted information because it contains a form of original plaintext that is unreadable by a human or computer without proper cipher to decrypt it. It is output from the algorithm.
5. **Decryption algorithm** – This is used to run encryption algorithms in reverse. Ciphertext and Secret key is input here and it produces plain text as output.



3.5. Cryptanalysis

Cryptanalysis is a means to decrypt ciphertext, ciphers, and cryptosystems. It works by understanding how they work to find ways to crack them despite the lack of plaintext source, encryption key, or algorithm used to mask information.

Ciphertext refers to encrypted text transformed from plaintext using an encryption algorithm. You can't read ciphertext until you convert it into plaintext or decrypt it with a key. A cipher, meanwhile, is an algorithm used to encrypt or decrypt data. It is a series of well-defined steps to follow to encrypt or decrypt plaintext. Finally, a cryptosystem is a suite of cryptographic algorithms used to secure or encrypt information. It typically uses three algorithms one for key generation, another for encryption, and one more for decryption.

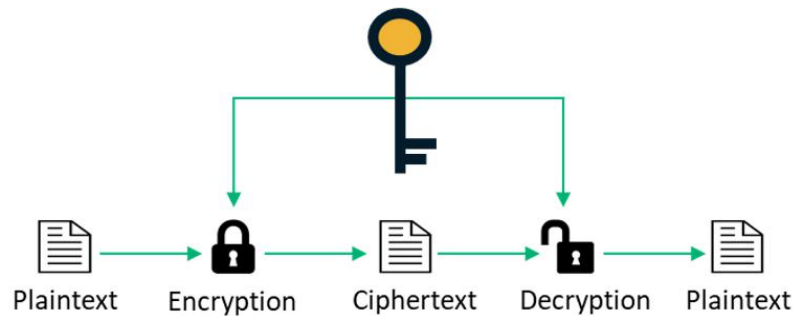
3.6. Cryptographic Systems

Most practical cryptographic systems combine two elements: A **process** or algorithm which is a set of rules that specify the mathematical steps needed to encipher or decipher data. A **cryptographic key** (a string of numbers or characters), or keys. The algorithm uses the key to select one relationship between plaintext and ciphertext out of the many possible relationships the algorithm provides. The selected relationship determines the composition of the algorithm's result. There are two main types of cryptographic processes:

- Symmetric, or secret key, algorithms, in which the same key value is used in both the encryption and decryption calculations.
- Asymmetric, or public key, algorithms, in which a different key is used in the decryption calculation than was used in the encryption calculation.

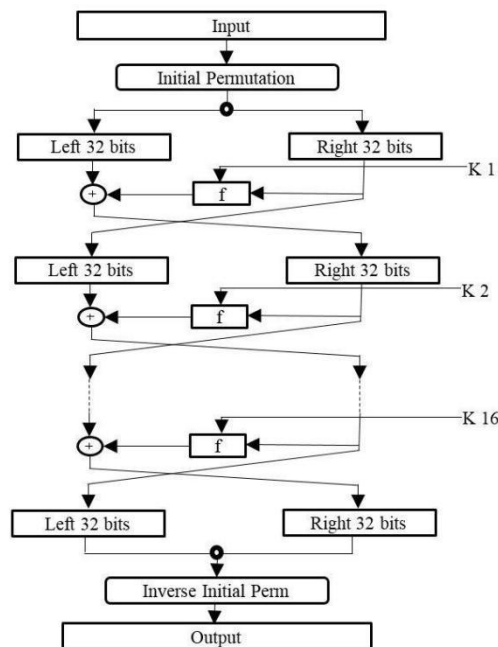
3.6.1. Symmetric key cryptography

In this scheme, the same key is used to encrypt the plaintext and decrypt the cipher text. Symmetric encryption can also be either a stream cipher or block cipher with the former being the process of encrypting each of input text one by one whereas the latter being the process of enciphering a block of the input text at once.



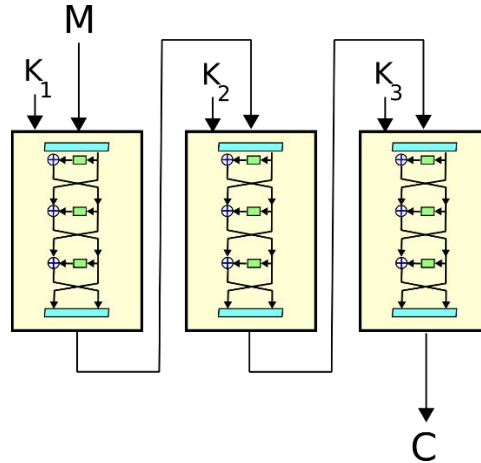
3.6.1.1. DES (Data Encryption Standard)

DES is a symmetric key encryption algorithm that uses 56 bits of encryption key. This is the most widely used block cipher encryption algorithm with block size of 64 bits. There are sixteen rounds of processing. from original 56-bit key sixteen sub keys are generated, one of which is used for each round.



3.6.1.2. 3DES (triple DES)

Triple DES is a symmetric key-block cipher which applies the DES cipher in triplicate. It encrypts with the first key (k_1), decrypts using the second key (k_2), then encrypts with the third key (k_3). There is also a two-key variant, where k_1 and k_3 are the same keys.



3.6.1.3. AES (Advanced Encryption Standard)

The more popular and widely adopted symmetric encryption algorithm likely to be encountered nowadays is the Advanced Encryption Standard (AES). It is found at least six times faster than triple DES.

A replacement for DES was needed as its key size was too small. With increasing computing power, it was considered vulnerable against exhaustive key search attack. Triple DES was designed to overcome this drawback but it was found slow.

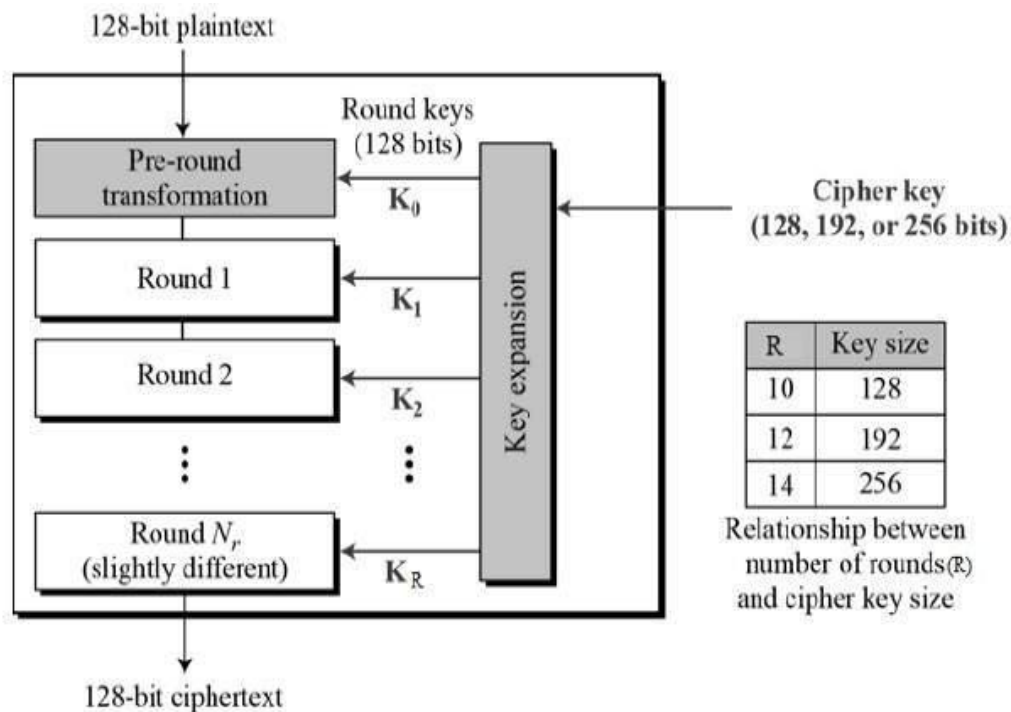
The features of AES are as follows –

- Symmetric key symmetric block cipher
- 128-bit data, 128/192/256-bit keys
- Stronger and faster than Triple-DES
- Provide full specification and design details
- Software implementable in C and Java

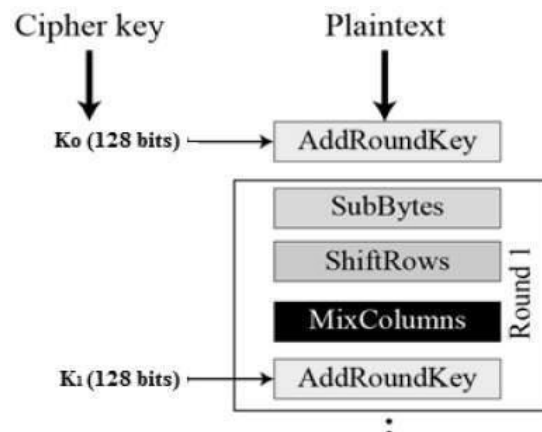
AES is an iterative rather than Feistel cipher. It is based on ‘substitution–permutation network’. It comprises of a series of linked operations, some of which involve replacing inputs by specific outputs (substitutions) and others involve shuffling bits around (permutations).

Interestingly, AES performs all its computations on bytes rather than bits. Hence, AES treats the 128 bits of a plaintext block as 16 bytes. These 16 bytes are arranged in four columns and four rows for processing as a matrix –

Unlike DES, the number of rounds in AES is variable and depends on the length of the key. AES uses 10 rounds for 128-bit keys, 12 rounds for 192-bit keys and 14 rounds for 256-bit keys. Each of these rounds uses a different 128-bit round key, which is calculated from the original AES key. The schematic of AES structure is given in the following illustration



Here, we restrict to description of a typical round of AES encryption. Each round comprises of four sub-processes. The first-round process is depicted below.



Byte Substitution (SubBytes)

The 16 input bytes are substituted by looking up a fixed table (S-box) given in design. The result is in a matrix of four rows and four columns.

Shiftrows

Each of the four rows of the matrix is shifted to the left. Any entries that ‘fall off’ are re-inserted on the right side of row. Shift is carried out as follows –

- First row is not shifted.
- Second row is shifted one (byte) position to the left.
- Third row is shifted two positions to the left.
- Fourth row is shifted three positions to the left.
- The result is a new matrix consisting of the same 16 bytes but shifted with respect to each other.

MixColumns

Each column of four bytes is now transformed using a special mathematical function. This function takes as input the four bytes of one column and outputs four completely new bytes, which replace the original column. The result is another new matrix consisting of 16 new bytes. It should be noted that this step is not performed in the last round.

Addroundkey

The 16 bytes of the matrix are now considered as 128 bits and are XORed to the 128 bits of the round key. If this is the last round then the output is the ciphertext. Otherwise, the resulting 128 bits are interpreted as 16 bytes and we begin another similar round.

Decryption Process

The process of decryption of an AES ciphertext is similar to the encryption process in the reverse order. Each round consists of the four processes conducted in the reverse order –

- Add round key
- Mix columns
- Shift rows
- Byte substitution

Since sub-processes in each round are in reverse manner, unlike for a Feistel Cipher, the encryption and decryption algorithms need to be separately implemented, although they are very closely related.

3.6.1.4. Block Cipher Modes

Block Cipher: A block cipher processes the input one block of elements at a time, produces an output block for each input block. For many applications block cipher are common in use.

- In cryptography, a **block cipher** is a symmetric key cipher operating on fixed-length groups of bits, called blocks, with an unvarying transformation.
- A block cipher encryption algorithm might take (for example) a 128-bit block of plaintext and key as input, and output a corresponding 128-bit block of cipher text.
- The exact transformation is controlled using a second input the secret key.
- Decryption is similar: the decryption algorithm takes, in this example, a 128-bit block of cipher text together with the secret key, and yields the original 128-bit block of plaintext.
- A message longer than the block size (128 bits in the above example) can still be encrypted with a block cipher by breaking the message into blocks and encrypting each block individually.
- However, in this method all blocks are encrypted with the same key, which degrades security (because each repetition in the plaintext becomes a repetition in the cipher text).
- To overcome this issue, modes of operation are used to make encryption probabilistic. Some modes of operation, despite the fact that their underlying implementation is a block cipher, allow the encryption of individual bits. The resulting cipher is called a stream cipher.
- An early and highly influential block cipher design was the Data Encryption Standard (DES), developed at IBM and published as a standard in 1977. A successor to DES, the Advanced Encryption Standard (AES), was adopted in 2001.

Other symmetric block ciphers:

- **RC5**
 - Developed by Ron Rivest in 1994
 - Suitable for hardware and software
 - Fast, simple
 - Adaptable to processors of different word lengths

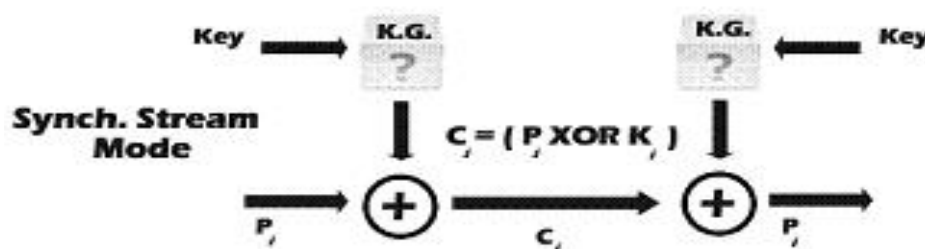
- Variable number of rounds
- Variable-length key
- Low memory requirement
- High security
- Data-dependent rotations
- Used in the Products from RSA Data Security
- **Cast-128**
 - Key size from 40 to 128 bits
 - The round function differs from round to round
- **International Data Encryption Algorithm (IDEA)**
 - A block cipher with block size 64 bits
 - 128-bit key
 - Used in PGP

Stream Ciphers: A stream cipher processes the input elements continuously, producing output one element at time, as it goes along. For some applications stream cipher is more appropriate.

- In cryptography, a **stream cipher** is a symmetric key cipher where plaintext bits are combined with a pseudorandom cipher bit stream (keystream), typically by an exclusive-or (xor) operation.

For example: if the next byte generated by the generator is 01101100 and the next plain text byte is 11001100, then the resulting ciphertext byte is:

	11001100	plaintext
⊕	01101100	keystream
	10100000	ciphertext



- In a stream cipher the plaintext digits are encrypted one at a time, and the transformation of successive digits varies during the encryption.
- An alternative name is a **state cipher**, as the encryption of each digit is dependent on the current state. In practice, the digits are typically single bits or bytes.
- Stream ciphers typically execute at a higher speed than block ciphers and have lower hardware complexity. However, stream ciphers can be susceptible to serious security problems if used incorrectly, they are vulnerable to attack if certain precautions are not followed; a) keys must never be used twice; b) valid encryption should never be relied on to indicate authenticity

Types of stream ciphers

A stream cipher generates successive elements of the keystream based on an internal state. This state is updated in essentially two ways: if the state changes independently of the plaintext or ciphertext messages, the cipher is classified as a *synchronous* stream cipher. By contrast, *self-synchronizing* stream ciphers update their state based on previous ciphertext digits.

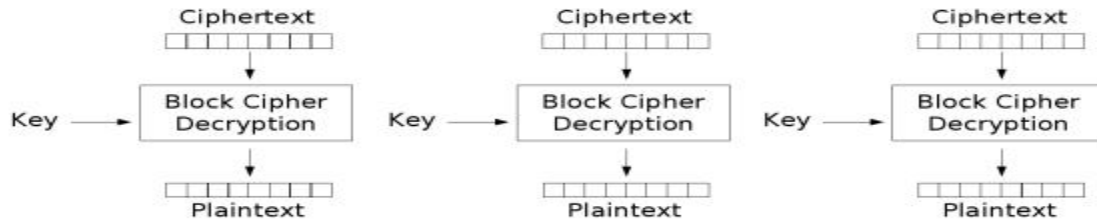
Example for stream cipher: RC4 is stream cipher. In cryptography, **RC4** is the most widely-used software stream cipher and is used in popular protocols such as Secure Sockets Layer (SSL) and WEP (to secure wireless networks). It is remarkable for its simplicity and speed in software, RC4 has weaknesses that argue against its use in new systems. It is especially vulnerable when the beginning of the output keystream is not discarded, or nonrandom or related keys are used; some ways of using RC4 can lead to very insecure cryptosystems such as WEP.

Cipher block modes of operation:

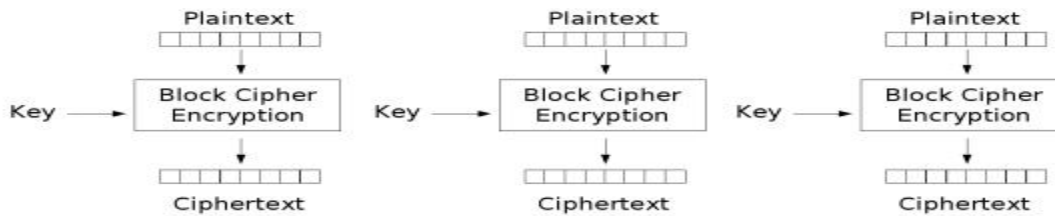
In a symmetric block cipher process one block of data at a time. In case the message longer than the block size (128 bits in the above example) can still be encrypted with a block cipher by breaking the message into blocks and encrypting each block individually. However, in this method all blocks are encrypted with the same key, which degrades security (because each repetition in the plaintext becomes a repetition in the ciphertext). To overcome this issue, modes of operation are used to make encryption probabilistic.

Electronic codebook (ECB)

The simplest of the encryption modes is the **electronic codebook** (ECB) mode. The message is divided into blocks and each block is encrypted separately. The term code book is used because, for a given key there is a unique cipher text for every 64-bit block of plain text.



Electronic Codebook (ECB) mode decryption



Electronic Codebook (ECB) mode encryption

Cipher-block chaining (CBC)

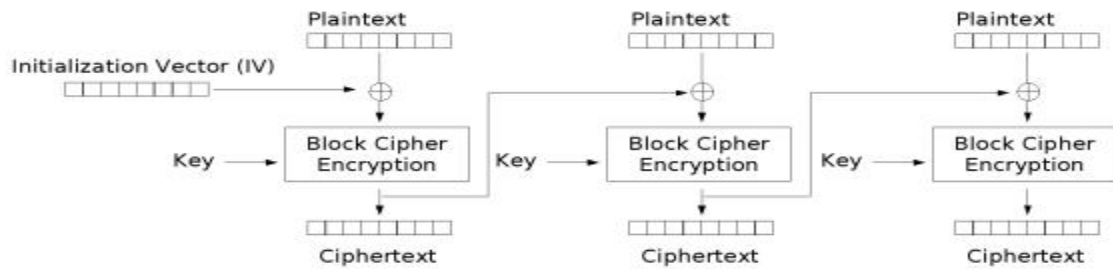
CBC mode of operation was invented by IBM in 1976. In the **cipher-block chaining** (CBC) mode, each block of plaintext is XORed with the previous cipher text block before being encrypted. This way, each cipher text block is dependent on all plaintext blocks processed up to that point. Also, to make each message unique, an initialization vector must be used in the first block.

If the first block has index 1, the mathematical formula for CBC encryption is

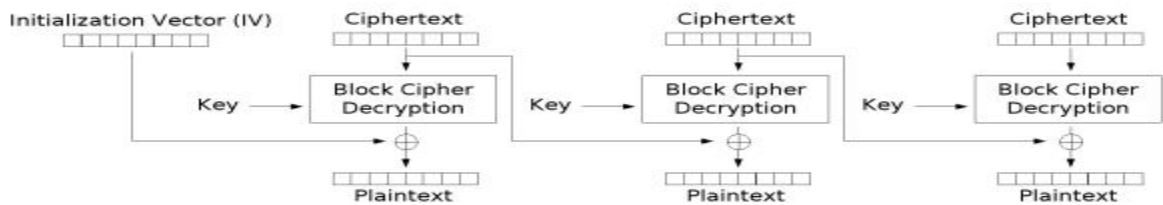
$$C_i = E_K(P_i \oplus C_{i-1}), C_0 = IV$$

while the mathematical formula for CBC decryption is

$$P_i = D_K(C_i) \oplus C_{i-1}, C_0 = IV$$



Cipher Block Chaining (CBC) mode encryption



Cipher Block Chaining (CBC) mode decryption

CBC has been the most commonly used mode of operation. Its main drawbacks are that encryption is sequential (i.e., it cannot be parallelized), and that the message must be padded to a multiple of the cipher block size. One way to handle this last issue is through the method known as cipher text stealing.

Note that a one-bit change in a plaintext affects all following cipher text blocks. A plaintext can be recovered from just two adjacent blocks of cipher text. As a consequence, decryption *can* be parallelized, and a one-bit change to the cipher text causes complete corruption of the corresponding block of plaintext, and inverts the corresponding bit in the following block of plaintext.

3.6.2. Public key cryptography

Public-key cryptography refers to a widely used set of methods for transforming a written message into a form that can be read only by the intended recipient. This cryptographic approach involves the use of asymmetric key algorithms, that is, the non-message information (the public key) needed to transform the message to a secure form is different from the information needed to reverse the process (the private key). The person who anticipates receiving messages first creates both a public key and an associated private key, and publishes the public key. When someone wants to send a secure message to the creator of these keys, the sender encrypts it

(transforms it to secure form) using the intended recipient's public key; to decrypt the message, the recipient uses the private key.

Thus, unlike symmetric key algorithms, a public key algorithm does not require a secure initial exchange of one or more secret keys between the sender and receiver. The particular algorithm used for encrypting and decrypting was designed in such a way that, while it is easy for the intended recipient to generate the public and private keys and to decrypt the message using the private key, and while it is easy for the sender to encrypt the message using the public key, it is extremely difficult for anyone to figure out the private key based on their knowledge of the public key.

The use of these keys also allows protection of the authenticity of a message by creating a digital signature of a message using the private key, which can be verified using the public key.

Public key cryptography is a fundamental and widely used technology around the world. It is the approach which is employed by many cryptographic algorithms and cryptosystems.

Public Key encryption scheme has six ingredients:

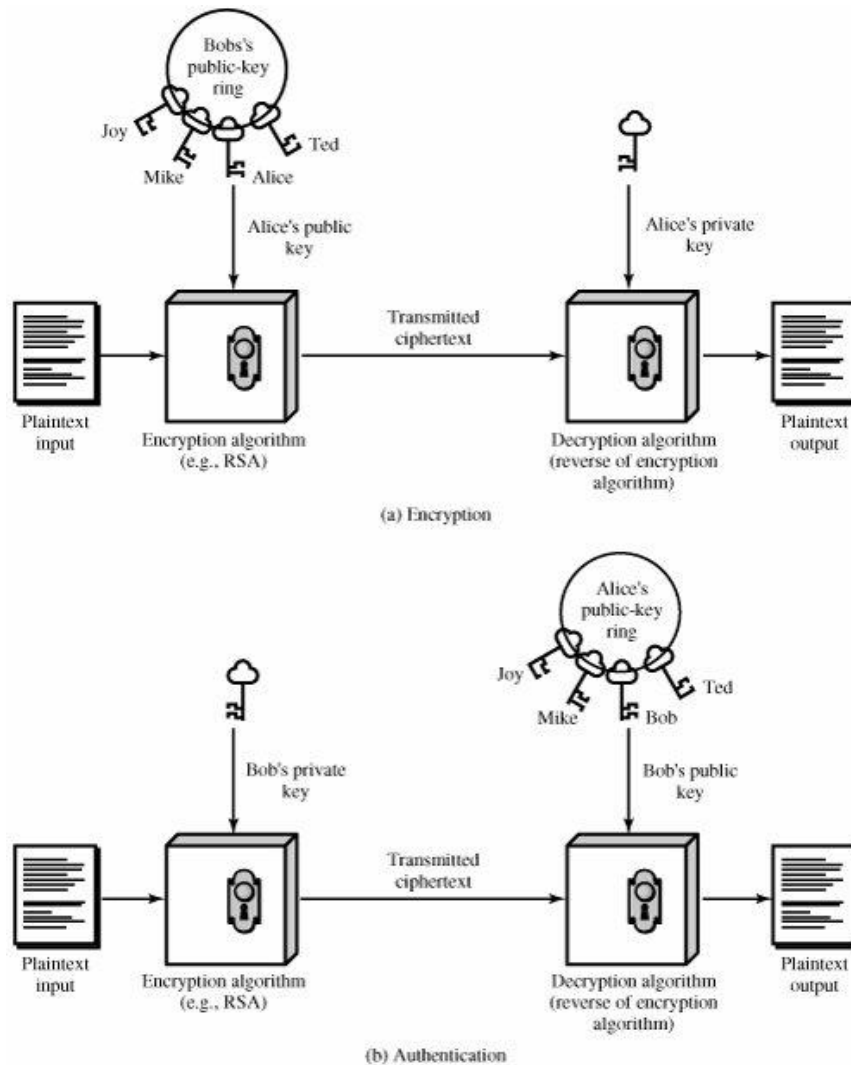
- **Plain text:** this is readable message or data that is fed into the algorithm as input.
- **Encryption algorithm:** The encryption algorithm performs various transformations
- **Public and Private Key:** This is a pair of keys that have been selected so that if one is used for encryption, the other is used for decryption.
- **Cipher text:** This is the scrambled message produced as output; it depends on the plaintext and the key. For a given message two different keys will produce two different cipher texts.
- **Decryption algorithm:** This algorithm accepts the cipher text and matching key and produces the original plain text.

The essential steps are the following:

1. Each user generates a pair of keys to be used for the encryption and decryption of message.
2. Each user places one of the two keys in a public register or other accessible file. This is public key and the companion key is kept private.

3. If Bob wishes to send a private message to Alice, Bob encrypts the message using Alice's public key.
4. When Alice receives the message, she decrypts it using her private key. No other recipient can decrypt the message because only Alice knows the Alice's private key.

Public Key encryption and Message authentication are shown below.



Difference between conventional encryption and public key encryption:

Conventional Encryption:

- The same algorithm with the same key is used for encryption and decryption.
- The sender and the receiver must share the algorithm and the key.

- The key must be kept secret.
- It must be impossible or at least impractical to decipher a message if no other information is available.
- The one of the advantages is Knowledge of algorithm plus samples of cipher must be insufficient to determine the key.
- It is also known as symmetric encryption.

Public –Key Encryption:

- One algorithm is used for encryption and decryption with a pair of keys, one for encryption and one for decryption.
- The sender and the receiver each must have one of the matched pair of keys.
- One of the two keys must be kept secret.
- It must be impossible or at least impractical to decipher a message if no other information is available.
- Knowledge of the algorithm plus one of the keys plus samples of cipher text must be insufficient to determine the other key. It is the advantage of this approach.
- It is also called as asymmetric encryption algorithm.

Applications for Public Key Cryptosystems:

Public key systems are characterized by the use of a cryptographic type of algorithm with two keys, one held private and one available publicly. Depending on the application, the sender uses either the sender's private key or receiver's public key, or both, to perform some type of Cryptographic function.

In broad terms, we can classify the use of public key cryptosystems into three categories.

- **Encryption/decryption** (provide secrecy): The sender encrypts a message with the recipient's public key.
- **Digital signatures** (provide authentication): The sender signs a message with its private key. Signing is achieved by a cryptographic algorithm applied to the message.
- **Key exchange** (of session keys): Two sides cooperate to exchange a session key. Several different approaches are possible, involving the private keys of one or both parties.

Some algorithms are suitable for all three applications, whereas others can be used only for one or two of these applications. The following table indicates the applications supported by the public key algorithms.

Algorithm	Encryption/decryption	Digital signature	Key exchange
RSA	Yes	Yes	Yes
Diffie-Hellman	No	No	Yes
DSS	No	Yes	No
Elliptic Curve	Yes	Yes	yes

Requirements for Public Key Cryptography:

All public key algorithms must follow some conditions mentioned below.

- It is computationally easy for a party B to generate a pair (public key PU_b , private key PR_b).
- It is computationally easy for a sender A, knowing the public key and the message to be encrypted, M to generate the corresponding cipher text. $C=E(PU_b,M)$
- It is computationally easy for a receiver B to decrypt the resulting cipher text using private key to recover the original message: $M=D(PR_b, C) = D[PR_b, E(PU_b,M)]$.
- It is computationally infeasible for an opponent, knowing the public key , PU_b to determine the private key, PR_b .
- It is computationally infeasible for an opponent, knowing the public key , PU_b and the cipher text C to recover the original message M.

Public Key Cryptography Algorithms:

The two most widely used public key algorithms are RSA and Diffie-Hellman. Other Public-Key Cryptographic Algorithms are

- Digital Signature Standard (DSS)
 - Makes use of the SHA-1
 - Not for encryption or key exchange
- Elliptic-Curve Cryptography (ECC)

- Good for smaller bit size
- Low confidence level, compared with RSA
- Very complex

3.6.2.1. Diffie-Hellman (DH)algorithm

DH algorithm is one of the asymmetric cryptographic key cryptographies.

In asymmetric encryption,

- Sender and receiver use different keys to encrypt and decrypt the message.
- The famous asymmetric encryption algorithms are-



As the name suggests,

- This algorithm is used to exchange the secret key between the sender and the receiver.
- This algorithm facilitates the exchange of secret key without actually transmitting it.

DH algorithm

- P and g are both publicly available numbers
 - ✓ P is at least 512 bits
- Users pick private values a and b
- Compute public values
 - ✓ $x = g^a \bmod p$
 - ✓ $y = g^b \bmod p$
- Public values x and y are exchanged
- Compute shared, private key
 - ✓ $k_a = y^a \bmod p$
 - ✓ $k_b = x^b \bmod p$
- Algebraically it can be shown that $k_a = k_b$
 - ✓ Users now have a symmetric secret key to encrypt

Example:

Alice and Bob compute symmetric keys

✓ $k_a = y^a \bmod p = 16^4 \bmod 23 = 9$

✓ $k_b = x^b \bmod p = 6^3 \bmod 23 = 9$

Alice and Bob now can talk securely!

3.6.2.2. RSA Algorithm

RSA algorithm is a public key encryption technique and is considered as the most secure way of encryption. It was invented by Rivest, Shamir and Adleman in year 1978 and hence name **RSA** algorithm.

The RSA algorithm holds the following features –

- RSA algorithm is a popular exponentiation in a finite field over integers including prime numbers.
- The integers used by this method are sufficiently large making it difficult to solve.
- There are two sets of keys in this algorithm: private key and public key.

You will have to go through the following steps to work on RSA algorithm

1. Randomly select two large prime numbers: - p, q
2. Computing their system modulus $n=p*q$

✓ Note $\phi(n)=(p-1)(q-1)$ (totient)

3. Selecting at random the encryption key e

Where $1 < e < \phi(n)$, $\gcd(e, \phi(n)) = 1$

4. Solve following equation to find decryption key d

✓ $e.d = 1 \bmod \phi(n)$ and $0 \leq d \leq n$

5. Publish their public encryption key: $\{e, n\}$
6. Keep secret private decryption key: $\{d, p, q\}$

Encryption using RSA

Consider a sender who sends the plain text message to someone whose public key is (n, e) . To encrypt the plain text message in the given scenario, use the following syntax.

$$C = m^e \bmod n, \text{ where } 0 \leq m < n$$

Decryption using RSA

The decryption process is very straightforward and includes analytics for calculation in a systematic approach. Considering receiver **C** has the private key **d**, the result modulus will be calculated as

$$\mathbf{m = c^d \bmod n}$$

Example 1

1. Select primes: $p=17$ & $q=11$
2. Compute $n = pq = 17 \times 11 = 187$
3. Compute $\phi(n) = (p-1)(q-1) = 16 \times 10 = 160$
4. Select e : $\gcd(e, 160) = 1$; choose $e=7$
5. Determine d : $de \equiv 1 \pmod{160}$ and $d < 160$ Value is $d=23$ since $23 \times 7 = 161 = 160 + 1$
6. Publish public key $\{7, 187\}$
7. Keep secret private key $\{23, 17, 11\}$
8. given message $M = 88$ (NB. $88 < 187$)
9. encryption:
$$C = 88^7 \bmod 187 = 11$$
10. decryption:
$$M = 11^{23} \bmod 187 = 88$$

Example 2:

Finding the decryption key using Euclidean and extended Euclidean algorithms

RSA: Steps to Creating Keys

4 - Calculating d using the following equation:
 $de \equiv 1 \pmod{\phi(n)}$

Euclidean Algorithm
 $40 = 5(7) + 5$
 $7 = 1(5) + 2$
 $5 = 2(2) + 1$

Extended Euclidean Algorithm
 $1 = 5 - 2(2)$
 $1 = 5 - 2(7 - 1(5))$
 $1 = 5 - 2(7) + 2(5)$
 $1 = 3(5) - 2(7)$
 $1 = 3(40 - 5(7)) - 2(7)$
 $1 = 3(40) - 15(7) - 2(7)$
 $1 = 3(40) - 17(7)$

$p = 11$
 $q = 5$
 $n = 55$
 $\phi(n) = 40$
 $e = 7$
 $d = 23$

$d = -17 \pmod{40}$
 $d = 23 \pmod{40}$

So $d = 23$, which is our decryption key.

3.6.3. Digital Signature

A **digital signature** or **digital signature scheme** is a mathematical scheme for demonstrating the authenticity of a digital message or document. A valid digital signature gives a recipient reason to believe that the message was created by a known sender, and that it was not altered in transit. Digital signatures are commonly used for software distribution, financial transactions, and in other cases where it is important to detect forgery or tampering. Digital signatures are easily transportable, cannot be imitated by someone else, and can be automatically time-stamped. The ability to ensure that the original signed message arrived means that the sender cannot easily repudiate it later.

A digital signature can be used with any kind of message, whether it is encrypted or not, simply so that the receiver can be sure of the sender's identity and that the message arrived intact. A digital certificate contains the digital signature of the certificate-issuing authority so that anyone can verify that the certificate is real.

How It Works

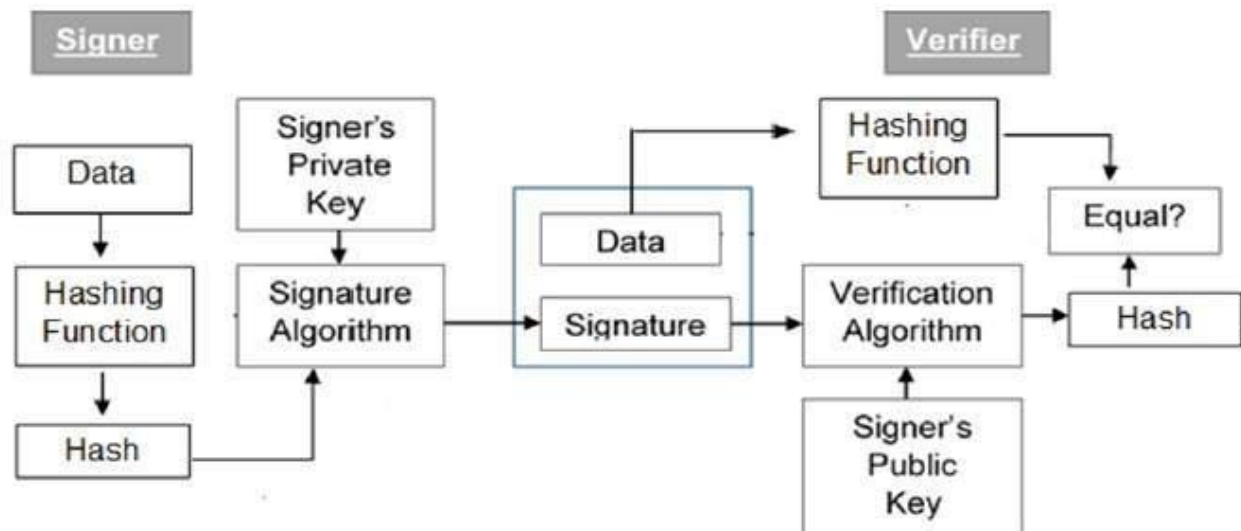
Assume you were going to send the draft of a contract to your lawyer in another town. You want to give your lawyer the assurance that it was unchanged from what you sent and that it is really from you.

1. You copy-and-paste the contract (it's a short one!) into an e-mail note.
2. Using special software, you obtain a message hash (mathematical summary) of the contract.
3. You then use a private key that you have previously obtained from a public-private key authority to encrypt the hash.
4. The encrypted hash becomes your digital signature of the message. (Note that it will be different each time you send a message.)

At the other end, your lawyer receives the message.

1. To make sure it's intact and from you, your lawyer makes a hash of the received message.
2. Your lawyer then uses your public key to decrypt the message hash or summary.
3. If the hashes match, the received message is valid.

The digital signature scheme is based on public key cryptography. The model of digital signature scheme is depicted in the following illustration.



3.6.4. Public key Infrastructure (PKI)

Bob wants to send a secure email message to Alice. This can be accomplished in the following manner:

1. Both Bob and Alice have their own key pairs. They have kept their private keys securely to themselves and have sent their public keys directly to each other.
2. Bob uses Alice's public key to encrypt the message and sends it to her.
3. Alice uses her private key to decrypt the message.

This simplified example highlights at least one obvious concern Bob must have about the public key he used to encrypt the message. That is, he cannot know with certainty that the key he used for encryption actually belonged to Alice. It is possible that another party monitoring the communication channel between Bob and Alice substituted a different key.

The public key infrastructure concept has evolved to help address this problem and others. A public key infrastructure (PKI) consists of software and hardware elements that a trusted third party can use to establish the integrity and ownership of a public key. The trusted party, called a *certification authority* (CA), typically accomplishes this by issuing signed (encrypted) binary certificates that affirm the identity of the certificate subject and bind that identity to the public key contained in the certificate. The CA signs the certificate by using its private key. It issues the corresponding public key to all interested parties in a self-signed CA certificate. When a CA is used, the preceding example can be modified in the following manner:

1. Assume that the CA has issued a signed digital certificate that contains its public key. The CA self-signs this certificate by using the private key that corresponds to the public key in the certificate.
2. Alice and Bob agree to use the CA to verify their identities.
3. Alice requests a public key certificate from the CA.
4. The CA verifies her identity, computes a hash of the content that will make up her certificate, signs the hash by using the private key that corresponds to the public key in the published CA certificate, creates a new certificate by concatenating the certificate content and the signed hash, and makes the new certificate publicly available.
5. Bob retrieves the certificate, decrypts the signed hash by using the public key of the CA, computes a new hash of the certificate content, and compares the two hashes. If the hashes match, the signature is verified and Bob can assume that the public key in the certificate does indeed belong to Alice.

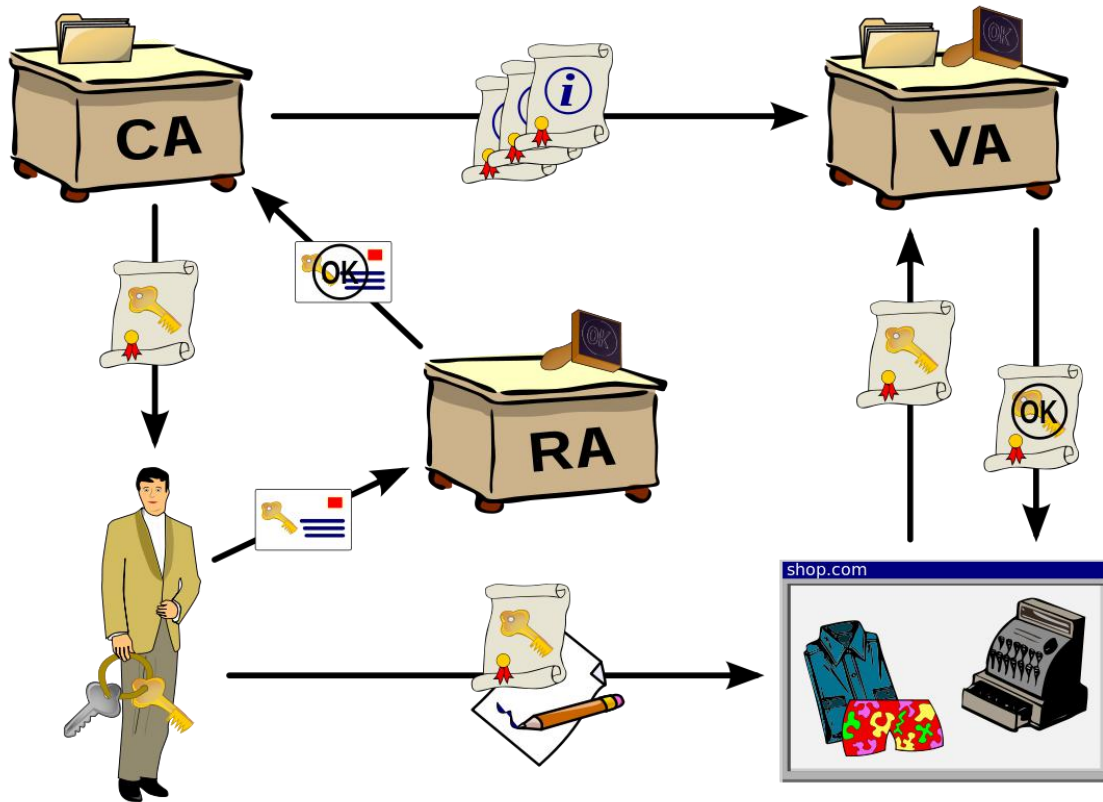
6. Bob uses Alice's verified public key to encrypt a message to her.
7. Alice uses her private key to decrypt the message from Bob.

In summary, the certificate signing process enables Bob to verify that the public key was not tampered with or corrupted during transit. Before issuing a certificate, the CA hashes the contents, signs (encrypts) the hash by using its own private key, and includes the encrypted hash in the issued certificate. Bob verifies the certificate contents by decrypting the hash with the CA public key, performing a separate hash of the certificate contents, and comparing the two hashes. If they match, Bob can be reasonably certain that the certificate and the public key it contains have not been altered.

A typical PKI consists of the following elements.

Element	Description
Certification Authority	Acts as the root of trust in a public key infrastructure and provides services that authenticate the identity of individuals, computers, and other entities in a network.
Registration Authority	Is certified by a root CA to issue certificates for specific uses permitted by the root. In a Microsoft PKI, a registration authority (RA) is usually called a subordinate CA.
Certificate Database	Saves certificate requests and issued and revoked certificates and certificate requests on the CA or RA.
Certificate Store	Saves issued certificates and pending or rejected certificate requests on the local computer.
Key Archival Server	Saves encrypted private keys in the certificate database for recovery after loss.

The X.509 public key infrastructure (PKI) standard identifies the requirements for robust public key certificates. A certificate is a signed data structure that binds a public key to a person, computer, or organization. Certificates are issued by *certification authorities* (CAs). All who are party to secure communications that make use of a public key rely on the CA to adequately verify the identities of the individuals, systems, or entities to which it issues certificates. The level of verification typically depends on the level of security required for the transaction. If the CA can suitably verify the identity of the requester, it signs (encrypts), encodes, and issues the certificate.



3.6.4.1. Key Distribution

In symmetric key cryptography, both parties must possess a secret key which they must exchange prior to using any encryption and key must be protected from access by others. Distribution of secret keys can be achieved in a number of ways for two parties A and B.

1. Key could be selected by A and physically delivered to B
2. A third party could select the key and physically deliver it to A and B.
3. If A and B have previously and recently used a key, one party could transmit the new key to the other, encrypted using the old key.
4. If A and B each have an encrypted connection to a third-party C, and C could deliver a key on the encrypted links to A and B.

Here option 1 and 2 are called manual delivery of a key which is not suggestible always. Option 3 is possible for either link encryption or end-to-end encryption, to provide keys for end-to-end encryption option 4 is preferable.

The following figure illustrates an implementation that satisfies option 4 for end-to-end encryption. For this scheme two kinds of keys are needed.

1. **Session key:** Data encrypted with a one-time session key. At the conclusion of the session the key is destroyed
2. **Permanent key:** Used between entities for the purpose of distributing session keys

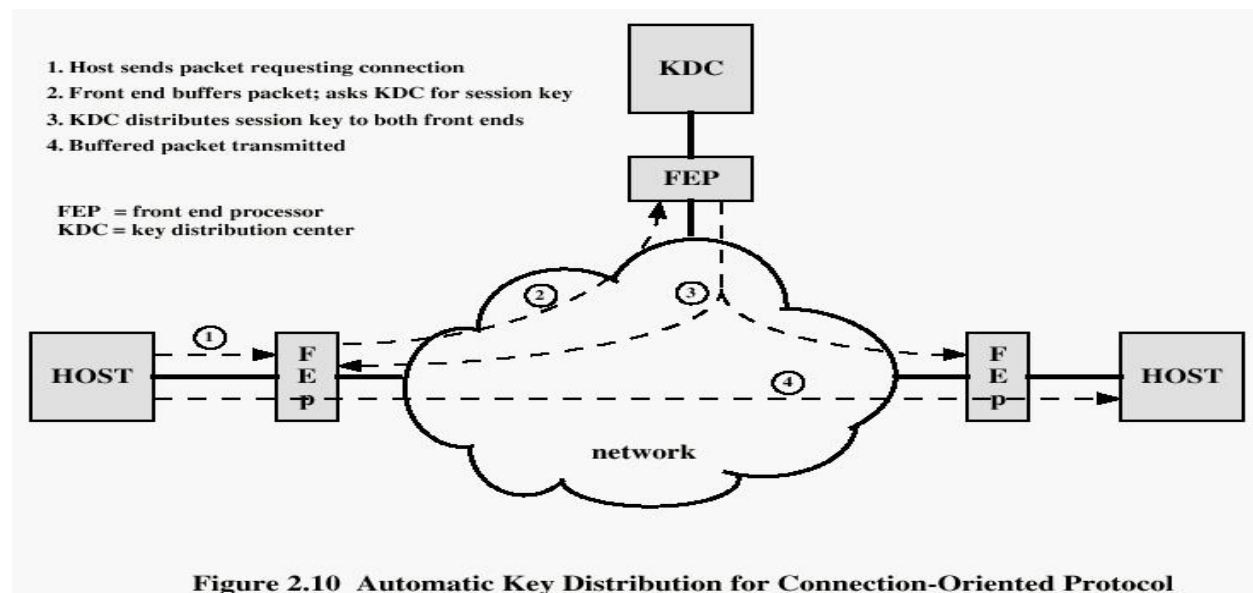


Figure 2.10 Automatic Key Distribution for Connection-Oriented Protocol

This configuration consists of the following elements:

- **Key distribution center (KDC):** The KDC determines which systems are allowed to communicate with each other. When the permission is granted for two systems to establish a connection, the key distribution center provides a one-time session key for that connection.
- **Security service module (SSM):** The module which may consists of functionality at one protocol layer, performs end-to-end encryption and obtains session keys on behalf of users.

The steps involved in the connection establishment are

- Step 1: When one host wishes to set up a connection to another host, it transmits a connection request packet.
- Step 2: The SSM saves that packet and applies to the KDC for permission to establish the connection.
- Step 3: The communication between SSM and KDC is encrypted using a master key shared by only this SSM and KDC. If KDC approves the connection request, it generates the session key and delivers it to the two appropriate SSMs using unique permanent key for each MMS.
- Step 4: Connection release.

Advantages with automatic key distribution approach:

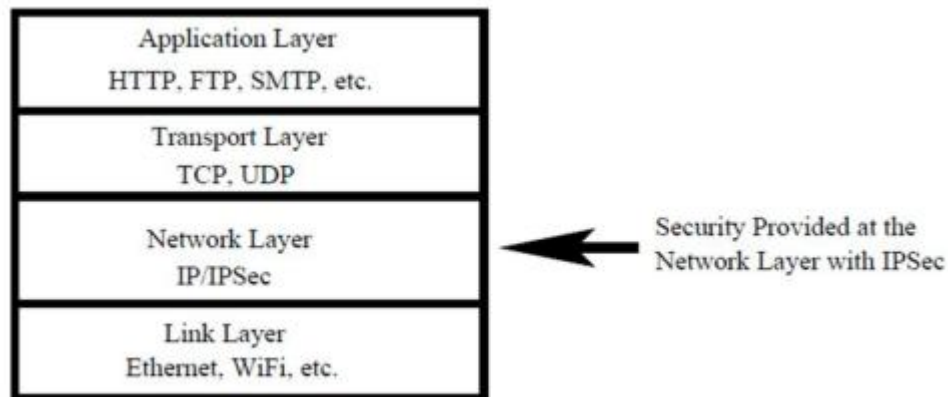
- Provides the flexibility and dynamic characteristics needed by the terminals to exchange data.
- All the user data exchanged between two end systems are encrypted by their respective MMS using the one-time session key.
- It uses public key encryption.

Chapter Four

4. Network Security

In today's highly networked world, we can't talk of computer security without talking of network security. Network security basically focuses on Internet/Intranet security (TCP/IP based networks) and attacks that use security holes of the network protocol and their defense mechanisms

Applications, systems, and networks can be made secure through the use of security protocols which provide a wide range of encryption and authentication services. Each security protocol is placed within several layers of a computing infrastructure, that is, network, transport, and application layers. Security at the network layer is provided with IPSec and at the transport layer with TLS/SSL.



4.1. Threats on network

Attackers exploit vulnerabilities of every protocol at every layer of the OSI model to achieve their goals. Spoofing and phishing are the most common types of attack to a network security. **Spoofing attack** is situation in which one person or program successfully imitate another by falsifying data and thereby gaining an illegitimate advantage.

IP spoofing

- ✓ Putting a wrong IP address in the source IP address of an IP packet

DNS spoofing

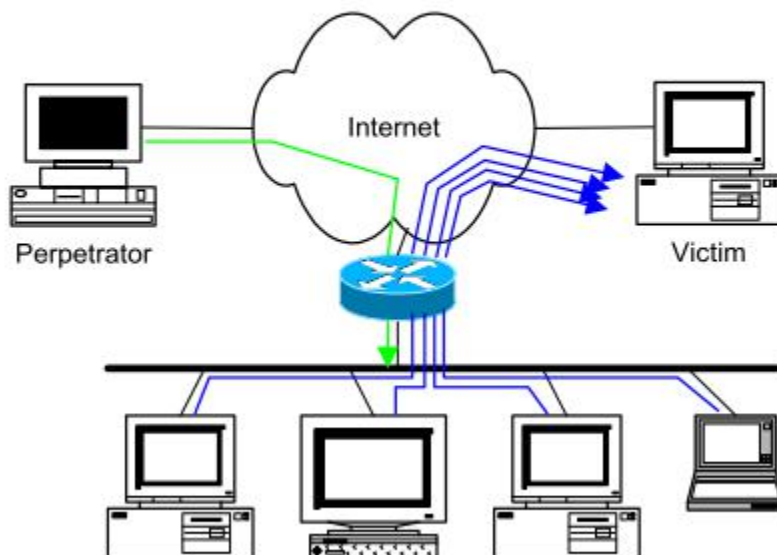
- ✓ Changing the DNS information so that it directs to a wrong machine

URL spoofing/Webpage phishing

- ✓ A legitimate web page such as a bank's site is reproduced in "look and feel" on another server under control of the attacker. This technique often directs users to enter detailed information at a fake website which appears almost identical to the legitimate one.
- ✓ Popular method of phishing is:
 - sending legitimate looking email containing a link to the fake website.
 - Registering fake website with a misspelled URL of popular websites
 - (www.microsoft.com www.microshoft.com) or
 - a different domain (www.whitehouse.gov www.whitehouse.com)

SMURF: Denial of service

- ICMP echo (spoofed source address of victim)
Sent to IP broadcast address
- ICMP echo reply



IP security (IPSec) is a capability that can be added to Internet Protocol (IPv4 or IPv6), by means of additional headers. IPSec encompasses three functional areas: authentication, confidentiality, and key management. Authentication makes use of Hash algorithms (SHA,MD-5,MAC)

Authentication can be applied to:

- the entire original IP packet (tunnel mode) or
- to all of the packet except for the IP header (transport mode).

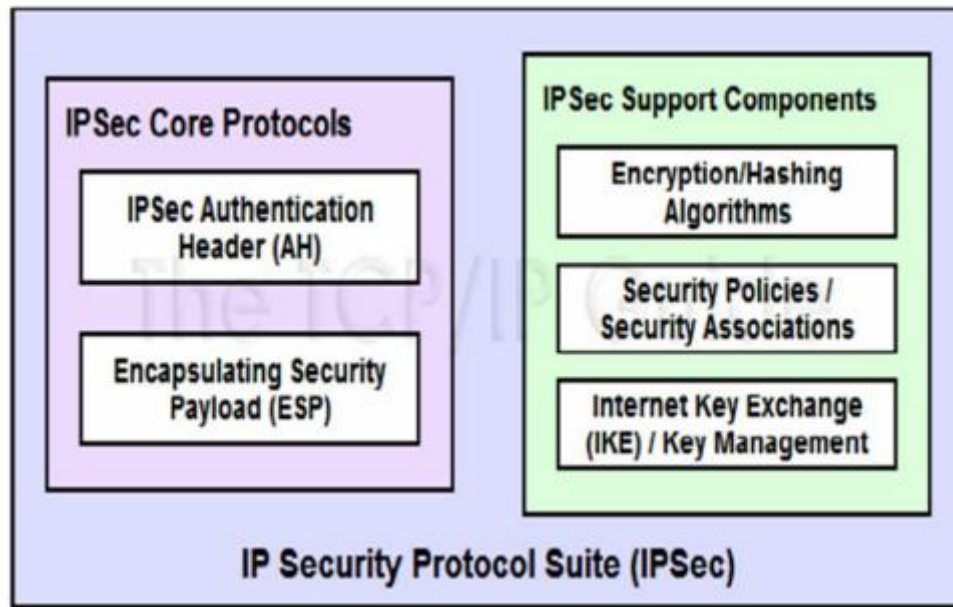
Confidentiality is provided by an encryption format known as encapsulating security payload. Both tunnel and transport modes can be accommodated. IPSec defines a number of techniques for key management. The Internet community has developed application-specific security mechanisms in a number of application areas, including:

- Electronic mail (S/MIME, PGP),
- client/server (Kerberos),
- Web access (Secure Sockets Layer), and others.

However, users have some security concerns that cut across protocol layers. For example, an enterprise can run a secure, private TCP/IP network by:

- disallowing links to untrusted sites,
- encrypting packets that leave the organization, and
- authenticating packets that enter the organization.

By implementing security at the IP level, an organization can ensure secure networking.



4.2. Trust, Weaknesses, Risk and Vulnerabilities

A **network security threat** is exactly that: a threat to your network and data systems. Any attempt to breach your network and obtain access to your data is a network threat.

There are different kinds of network threats, and each has different goals. Some, like **distributed denial-of-service (DDoS) attacks**, seek to shut down your network or servers by overwhelming it with requests. Other threats, like malware or credential theft, are aimed at stealing your data. Still others, like spyware, will insert themselves into your organization's network, where they'll lie in wait, collecting information about your organization.

There are four main kinds of network threats:

1. **External threats:** Threats made by outside organizations or individuals, attempting to get into your network.
2. **Internal threats:** These are threats from malicious insiders, such as disgruntled or improperly vetted employees who are working for someone else. These are common. According to Forrester, 46% of breaches in 2019 involved insiders like employees and third-party partners.

3. **Structured threats:** Organized attacks by attackers who know what they're doing and have a clear aim or goal in mind. State-sponsored attacks, for example, fall into this category.
4. **Unstructured attacks:** disorganized attacks, often by amateurs with no concrete goal in mind.

If threats are attackers throwing rocks at a wall, a **vulnerability** is a weak spot in the wall — a place where attackers can break a window, or pull out a loose rock and let themselves in. Put simply, vulnerabilities are flaws in your systems that can be exploited by attackers. These are often not malicious errors, but simply mistakes or things that have been overlooked.

what are common network threats

Network threats come in a variety of forms and are constantly evolving and changing. The most common threats are likely familiar to you already.

1. **Phishing:** Phishing attacks are attempts to trick people into opening suspicious links or downloading malicious programs. They range from the easily-spotted to sophisticated cons targeting a specific individual. Phishing campaigns are currently one of the most popular methods of attack, according to Microsoft.
2. **Ransomware:** Often delivered via successful phishing campaigns, ransomware enters your systems, encrypts your data, and holds it hostage until you pay the attackers' ransom. Once the ransom is paid, the attackers will allegedly give you control of your data, but criminals don't always keep their word.
3. **Malware:** Any malicious program that enters your system, malware can be ransomware, a virus, or a worm that infects first a device, then the whole network.
4. **DDoS attacks:** DDoS attacks overwhelm your servers with requests for information, forcing sites, servers, and applications to shut down.
5. **Advanced Persistent Threats (APTs):** During an APT attack, an unauthorized attacker codes into a system network and stays there quietly, collecting information.
6. **SQL Injection:** SQL injection attacks inject malicious code into a site or application using SQL queries in order to exploit security vulnerabilities and obtain or destroy private data.

4.3. TCP/IP Suit Weaknesses and Buffer Overflows

All major OS have made improvements in their implementations of the protocol stack that mitigate or disable many of the attacks described below. Of course, the attack tools also improve. A number of enhancements for TCP/IP have been made that are not yet in common use. Several of them (e.g., DNSSEC and IPv6) involve heavy use of encryption and require more computing power. As computing power in end-user hosts increases, we expect to see these universally deployed.

Attack techniques:

Sniffing: is eavesdropping on the network. A (packet) sniffer is a wire-tap program. Sniffing is the act by machine S of making copies of a network packet sent by machine A intended to be received by machine B. Such sniffing, strictly speaking, is not a TCP/IP problem, but it is enabled by the near-universal choice of Ethernet, a broadcast media, as the physical and data link layers. Sniffing can be used for monitoring the health of a network as well as capturing the passwords used in telnet, rlogin, and FTP connections. Attackers sniff the data necessary in the exploits described below. Depending on the equipment used in a LAN, a sniffer needs to be run either on the victim machine whose traffic is of interest or on some other host in the same subnet as the victim. An attacker at large on the Internet has other techniques that make it possible to install remotely a sniffer on the victim machine. Attacks that do not sniff and therefore cannot see the information in the packet flows are called blind attacks.

Buffer overflow: A large number of TCP/IP server programs suffer from a class of programming errors known as buffer overflows. Many of these server programs run with the privileges of a super user. Among the many servers that suffer from such bugs are several implementations of FTP servers, the ubiquitous DNS server program called bind, the popular mail server called **send-mail**, and the **Web server IIS**, to name a few. An attacker supplies cleverly constructed inputs to such programs causing them to transfer control to executable code she has supplied. A typical code produces a shell that she can interact with from a remote machine with all the privileges of the super user.

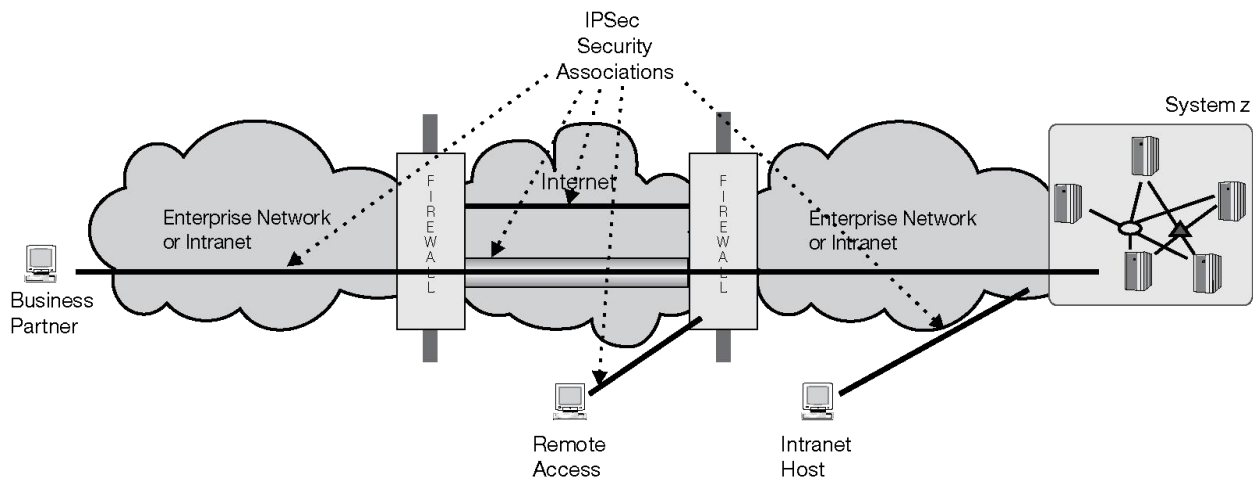
Spoofing: refers to altering (portions of) a packet so that the overall packet remains structurally legitimate (e.g., checksums are valid) but the “info” it contains is fake. Spoofing often accompanies sniffing, but may newly manufacture packets with fake values. Spoofed packets are injected into the network.

4.4. Network security protocols

Network security: This area covers the use of cryptographic algorithms in network protocols and network applications. This topic describes network security protocols that you can use to protect data in your network.

IPSec

IPSec is defined by the IPSec Working Group of the IETF. It provides authentication, integrity, and data privacy between any two IP entities. Management of cryptographic keys and security associations can be done manually or dynamically using an IETF-defined key management protocol called Internet Key Exchange (IKE). With IPSec, you can create virtual private networks (VPN). A VPN enables an enterprise to extend its private network across a public network, such as the Internet, through a secure tunnel called a security association. IPSec VPNs enable the secure transfer of data over the public Internet for same-business and business-to-business communications, and protect sensitive data within the enterprise's internal network.



SSL and TLS

The SSL protocol provides data encryption, data origin authentication, and message integrity. It also provides server and client authentication using X.509 certificates. SSL begins with a handshake during which the server is authenticated to the client using X.509 certificates. Also, the client can optionally be authenticated to the server. During the handshake, security session parameters, such as cryptographic algorithms, are negotiated and session keys are created. After the handshake, the data is protected during transmission with data origin authentication and optional encryption using the session keys.

The cryptographic algorithms that are used for the SSL session are based on the algorithms that the server and client are able to use. During the SSL handshake, the client and server exchange a list of algorithms. The algorithm that is selected is based on the best match between the client list and the server list. You can limit the selectable algorithms by configuring a subset of allowable algorithms at the server. Servers can support encryption by using AES, Triple DES, and other

encryption algorithms (RC2, RC4, and DES). Cryptographic hardware, if available, is used for certain cryptographic algorithms. TLS is based on SSL and is defined by the Internet Engineering Task Force (IETF) in RFCs 2246, 4346 and 5246. SSL is not defined by the IETF.

Kerberos

Kerberos is a network authentication protocol that is designed to provide strong authentication for client/server applications using secret-key cryptography. The Kerberos network authentication protocol assumes that services and workstations communicate over an insecure network. It allows clients and servers to do either one way, or two-way (mutual) authentication. It allows for data encryption and prevents passwords from having to be retyped to access networked services and also prevents their transmission in plain text over the network. This feature can help reduce the need to manage multiple passwords.

4.5.Application layer security

Application layer security refers to ways of protecting web applications at the application layer (layer 7 of the OSI model) from malicious attacks. Since the application layer is the closest layer to the end user, it provides hackers with the largest threat surface. Poor app layer security can lead to performance and stability issues, data theft, and in some cases the network being taken down.

Examples of application layer attacks include distributed denial-of-service attacks (DDoS) attacks, HTTP floods, SQL injections, cross-site scripting, parameter tampering, and Slowloris attacks. To combat these and more, most organizations have an arsenal of application layer security protections, such as web application firewalls (WAFs), secure web gateway services, and others.

4.6.Wireless Security

Wireless security is the prevention of unauthorized access or damage to computers or data using wireless networks, which include Wi-Fi networks. The term may also refer to the protection of the wireless network itself from adversaries seeking to damage the confidentiality, integrity, or availability of the network. The most common type is **Wi-Fi security**, which includes Wired Equivalent Privacy (WEP) and Wi-Fi Protected Access (WPA). WEP is an old IEEE 802.11 standard from 1997. It is a notoriously weak security standard: the password it uses

can often be cracked in a few minutes with a basic laptop computer and widely available software tools. WEP was superseded in 2003 by WPA, or Wi-Fi Protected Access. WPA was a quick alternative to improve security over WEP. The current standard is WPA2; some hardware cannot support WPA2 without firmware upgrade or replacement. WPA2 uses an encryption device that encrypts the network with a 256-bit key; the longer key length improves security over WEP. Enterprises often enforce security using a certificate-based system to authenticate the connecting device, following the standard 802.11X.

Chapter Five

5. Security Mechanisms

Security mechanisms are technical tools and techniques that are used to implement security services. A mechanism might operate by itself, or with others, to provide a particular service.

5.1. Firewall

A firewall is a network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules. firewalls establish a barrier between secured and controlled internal networks that can be trusted and untrusted outside networks, such as the Internet. A firewall can be hardware, software, or both.

Types of firewalls:

Proxy Firewall: An early type of firewall device, a proxy firewall serves as the gateway from one network to another for a specific application. Proxy servers can provide additional functionality such as content caching and security by preventing direct connections from outside the network. However, this also may impact throughput capabilities and the applications they can support.

Stateful inspection firewall: Now thought of as a “traditional” firewall, a stateful inspection firewall allows or blocks traffic based on state, port, and protocol. It monitors all activity from the opening of a connection until it is closed. Filtering decisions are made based on both administrator-defined rules as well as context, which refers to using information from previous connections and packets belonging to the same connection.

Unified threat management (UTM) firewall: A UTM device typically combines, in a loosely coupled way, the functions of a stateful inspection firewall with intrusion prevention and antivirus. It may also include additional services and often cloud management. UTMs focus on simplicity and ease of use.

Next-generation firewall (NGFW): Firewalls have evolved beyond simple packet filtering and stateful inspection. Most companies are deploying next-generation firewalls to block modern threats such as advanced malware and application-layer attacks.

According to Gartner, Inc.'s definition, a next-generation firewall must include:

- Standard firewall capabilities like stateful inspection
- Integrated intrusion prevention
- Application awareness and control to see and block risky apps
- Upgrade paths to include future information feeds
- Techniques to address evolving security threats

While these capabilities are increasingly becoming the standard for most companies, NGFWs can do more.

5.2. Proxy server

A **proxy server** is any machine that translates traffic between networks or protocols. It's an intermediary server separating end-user clients from the destinations that they browse. Proxy servers provide varying levels of functionality, security, and privacy depending on your use case, needs, or company policy.

Some people use proxies for personal purposes, such as hiding their location while watching movies online, for example. For a company, however, they can be used to accomplish several key tasks such as:

1. Improve security
2. Secure employees' internet activity from people trying to snoop on them
3. Balance internet traffic to prevent crashes
4. Control the websites employees and staff access in the office
5. Save bandwidth by caching files or compressing incoming traffic

How a proxy server works?

Because a proxy server has its own IP address, it acts as a go-between for a computer and the internet. Your computer knows this address, and when you send a request on the internet, it is routed to the

proxy, which then gets the response from the web server and forwards the data from the page to your computer's browser, like Chrome, Safari, Firefox, or Microsoft Edge.

How to Get a Proxy?

There are hardware and software versions. Hardware connections sit between your network and the internet, where they get, send, and forward data from the web. Software proxies are typically hosted by a provider or reside in the cloud. You download and install an application on your computer that facilitates interaction with the proxy. Often, a software proxy can be obtained for a monthly fee. Sometimes, they are free. The free versions tend to offer users fewer addresses and may only cover a few devices, while the paid proxies can meet the demands of a business with many devices.

How Is the Server Set Up?

To get started with a proxy server, you have to configure it in your computer, device, or network. Each operating system has its own setup procedures, so check the steps required for your computer or network. In most cases, however, setup means using an automatic configuration script. If you want to do it manually, there will be options to enter the IP address and the appropriate port.

How Does the Proxy Protect Computer Privacy and Data?

A proxy server performs the function of a firewall and filter. The end-user or a network administrator can choose a proxy designed to protect data and privacy. This examines the data going in and out of your computer or network. It then applies rules to prevent you from having to expose your digital address to the world. Only the proxy's IP address is seen by hackers or other bad actors. Without your personal IP address, people on the internet do not have direct access to your personal data, schedules, apps, or files.

With it in place, web requests go to the proxy, which then reaches out and gets what you want from the internet. If the server has encryption capabilities, passwords and other personal data get an extra tier of protection.

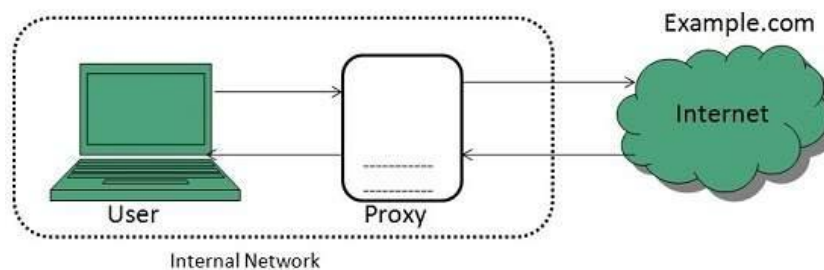
Benefits of a Proxy Server

Proxies come with several benefits that can give your business an advantage:

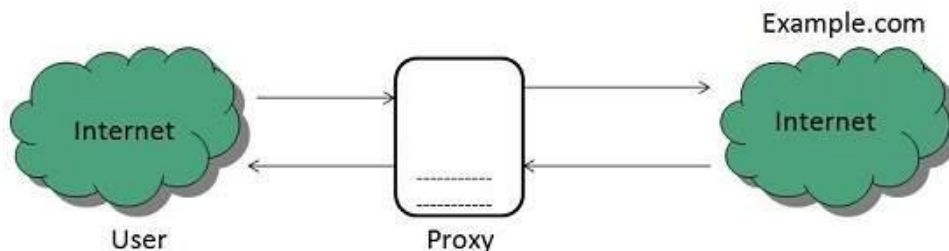
1. **Enhanced security:** Can act like a firewall between your systems and the internet. Without them, hackers have easy access to your IP address, which they can use to infiltrate your computer or network.
2. **Private browsing, watching, listening, and shopping:** Use different proxies to help you avoid getting inundated with unwanted ads or the collection of IP-specific data.
3. **Access to location-specific content:** You can designate a proxy server with an address associated with another country. You can, in effect, make it look like you are in that country and gain full access to all the content computers in that country are allowed to interact with.
4. **Prevent employees from browsing inappropriate or distracting sites:** You can use it to block access to websites that run contrary to your organization's principles. Also, you can block sites that typically end up distracting employees from important tasks. Some organizations block social media sites like Facebook and others to remove time-wasting temptations.

Types of proxy servers

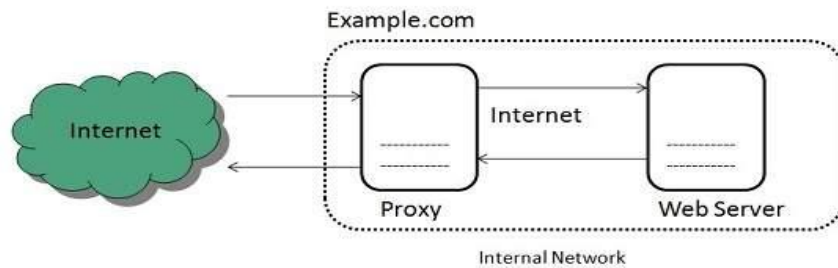
Forward Proxies: In this the client requests its internal network server to forward to the internet.



Open Proxy: Open Proxies helps the clients to conceal their IP address while browsing the web.

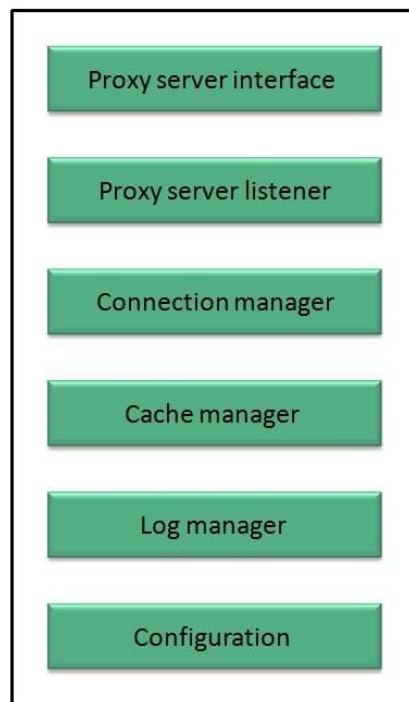


Reverse proxies: In this the requests are forwarded to one or more proxy servers and the response from the proxy server is retrieved as if it came directly from the original Server.



Architecture

The proxy server architecture is divided into several modules as shown in the following diagram:



Proxy user interface

This module controls and manages the user interface and provides an easy-to-use graphical interface, window and a menu to the end user. This menu offers the following functionalities:

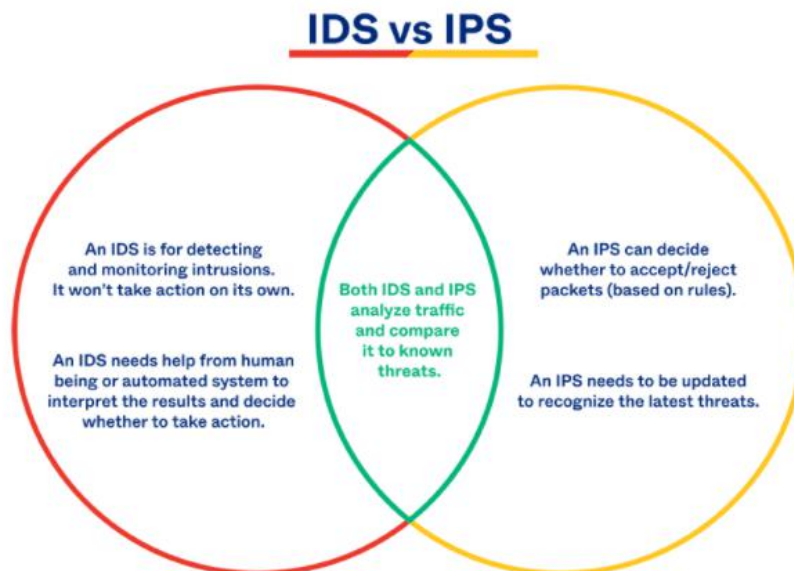
- Start proxy
- Stop proxy
- Exit
- Blocking URL
- Blocking client

- Manage log
- Manage cache
- Modify configuration

5.3. IDS/IPS

An intrusion detection system (IDS) monitors traffic on your network, analyzes that traffic for signatures matching known attacks, and when something suspicious happens, you're alerted. In the meantime, the traffic keeps flowing.

An intrusion prevention system (IPS) also monitors traffic. But when something unusual happens, the traffic stops altogether until you investigate and decide to open the floodgates again.



What Is an IDS?

You want to protect the assets on your server. But you don't want to slow down the traffic, even if a problem occurs. An intrusion detection system (IDS) could be the solution you've been looking for. Five main types of IDS exist.

Network: Choose a point on your network and examine all traffic on all devices from that point.

Host: Examine traffic to and from independent devices within your network, and leave all other devices alone.

Protocol-based: Place protection between a device and the server, and monitor all traffic that goes between them.

Application protocol-based: Place protection within a group of servers and watch how they communicate with one another.

Hybrid: Combine some of the approaches listed above into a system made just for you.

What Is an IPS?

You want to stop an attack as soon as it's discovered, even if that means closing down legitimate traffic for security concerns. An intrusion protection system (IPS) could be just right for you.

The goal of an IPS is to prevent damage. While you're kept in the loop about the attack, the system is already working to keep things safe.

An IPS can protect against exterior intruders. But people within your organization can also take steps that harm your security. An IPS can protect against these actions too, so it can help train your employees about what is allowed and what is not.

Four main types of IPS exist:

Network: Analyze and protect traffic on your network.

Wireless: Observe anything happening within a wireless network and defend against an attack launched from there.

Network behavior: Spot attacks that involve unusual traffic on your network.

Host-based: Scan events that occur within a host you specify.

5.4. Virtual Private network

A virtual private network, or VPN, is an encrypted connection over the Internet from a device to a network. The encrypted connection helps ensure that sensitive data is safely transmitted. It prevents unauthorized people from eavesdropping on the traffic and allows the user to conduct work remotely. VPN technology is widely used in corporate environments.

How does a virtual private network (VPN) work?

A VPN extends a corporate network through encrypted connections made over the Internet. Because the traffic is encrypted between the device and the network, traffic remains private as it travels. An employee can work outside the office and still securely connect to the corporate network. Even smartphones and tablets can connect through a VPN.

What is secure remote access?

Secure remote access provides a safe, secure way to connect users and devices remotely to a corporate network. It includes VPN technology that uses strong ways to authenticate the user or device. VPN technology is available to check whether a device meets certain requirements, also called a device's posture, before it is allowed to connect remotely.

Is VPN traffic encrypted?

Yes, traffic on the virtual network is sent securely by establishing an encrypted connection across the Internet known as a tunnel. VPN traffic from a device such as a computer, tablet, or smartphone is encrypted as it travels through this tunnel. Offsite employees can then use the virtual network to access the corporate network.

Types of VPN

Remote access

A remote access VPN securely connects a device outside the corporate office. These devices are known as endpoints and may be laptops, tablets, or smartphones. Advances in VPN technology have allowed security checks to be conducted on endpoints to make sure they meet a certain posture before connecting. Think of remote access as computer to network.

Site-to-site

A site-to-site VPN connects the corporate office to branch offices over the Internet. Site-to-site VPNs are used when distance makes it impractical to have direct network connections between these offices. Dedicated equipment is used to establish and maintain a connection. Think of site-to-site access as network to network.

Chapter Six

6. Authentication and Access control

6.1. Authentication basics

Authentication: is the process of determining whether someone or something is, in fact, who or what it says it is. Authentication technology provides access control for systems by checking to see if a user's credentials match the credentials in a database of authorized users or in a data authentication server.

6.1.1. Password and passphrase

While passwords and passphrases essentially serve the same purpose – providing access to secure services or sensitive information, passwords are generally short, hard to remember, and easier to crack. Passphrases are easier to remember and type. They are considered more secure due to the overall length of the passphrase and the fact that it shouldn't need to be written down.

6.1.2. Biometrics

Biometrics is the measurement and statistical analysis of people's unique physical and behavioral characteristics. The technology is mainly used for identification and access control or for identifying individuals who are under surveillance. The basic premise of biometric authentication is that every person can be accurately identified by intrinsic physical or behavioral traits. The term *biometrics* is derived from the Greek words *bio*, meaning *life*, and *metric*, meaning *to measure*.

Biometrics are largely used because of two major benefits:

- **The convenience of use:** Biometrics are always with you and cannot be lost or forgotten.
- **Difficult to steal or impersonate:** Biometrics can't be stolen like a password or key can.

Two main types of biometrics: Biometric recognition is the individual's presentation of his unique biometric parameter and the process of comparing it with the entire database of available data. Biometric readers are used to retrieving this kind of personal data.

Physical identification methods are based on the analysis of the invariable physiological characteristics of a person.

These characteristics include:

- Face shape and geometry
- Fingerprints
- The shape and structure of the skull
- Retina (rarely used as an identifier).
- The iris of the eye
- Palm, hand, or finger geometry
- Facial thermography, hand thermography
- Drawing of veins on the palm or finger
- DNA

Behavioral identification methods are based on the analysis of a person's behavioral characteristics — the characteristics inherent in each person in the process of reproducing an action.

Behavioral methods of user identification are divided by:

- Signature recognition
- Keystroke dynamics
- Speaker recognition
- Gait recognition.

6.1.3. AAA server

AAA (Authentication, Authorization and Accounting) is a standard-based framework used to control who is permitted to use network resources (through authentication), what they are authorized to do (through authorization), and capture the actions performed while accessing the network (through accounting).

Authentication – The process by which it can be identified that the user, which wants to access the network resources, valid or not by asking some credentials such as username and password. Common methods are to put authentication on console port, AUX port, or vty lines. As network administrators, we can control how a user is authenticated if someone wants to access the network. Some of these methods include using the local database of that device (router) or sending authentication requests to an external server like the ACS server. To specify the method to be used for authentication, a default or customized authentication method list is used.

Authorization

It provides capabilities to enforce policies on network resources after the user has gained access to the network resources through authentication. After the authentication is successful, authorization can be used to determine what resources the user is allowed to access and the operations that can be performed.

Accounting

It provides means of monitoring and capturing the events done by the user while accessing the network resources. It even monitors how long the user has access to the network. The administrator can create an accounting method list to specify what should be accounted for and to whom the accounting records should be sent.

6.1.4. Smart cards and memory cards

Smart cards are not used for transferring financial information alone and can be used for a variety of identification purposes. Some companies give their employees smart identification cards as an added measure of security for the organization and for the individuals who work there. They are important for security purposes in all of their applications. In an age of increasing technology hacks and security challenges, smart cards give users and institutions extra protection for transactions and account information.

A **memory card** is a type of storage device that is used for storing media and data files. A memory card is mainly used as a primary and portable flash memory in mobile phones, cameras, and other portable and handheld devices. PC Cards (PCMCIA) were a predecessor of modern memory cards that were introduced for commercial purposes. Besides providing non-volatile media storage, a memory card also uses solid-state media technology, which lowers the chances of mechanical problems, such as those found in traditional hard drives. A memory card is also known as a flash card.

6.2. Access control basics

Access control is identifying a person doing a specific job, authenticating them by looking at their identification, then giving that person only the key to the door or computer that they need access to and nothing more. In the world of information security, one would look at this as granting an individual permission to get onto a network via a username and password, allowing them access to files, computers, or other hardware or software the person requires, and ensuring they have the right level of permission (i.e., read-only) to do their job.

6.3. Access control models

Access control models are methods which enables one to grant the right level of permission to an individual so that they can perform their duties based on the rated permission.

Access control models have four flavors: Mandatory Access Control (MAC), Role-Based Access Control (RBAC), Discretionary Access Control (DAC), and Rule-Based Access Control (RBAC or RB-RBAC).

6.3.1. The Mandatory Access Control

This model gives only the owner and custodian management of the access controls. This means the end user has no control over any settings that provide any privileges to anyone. There are two security models associated with MAC: Biba and Bell-LaPadula. The Biba model is focused on the integrity of information, whereas the Bell-LaPadula model is focused on the confidentiality of information. Biba is a setup where a user with lower clearance can read higher-level information (called “read up”) and a user with high-level clearance can write for lower levels of clearance (called “write down”). The Biba model is typically utilized in businesses where employees at lower levels can read higher-level information and executives can write to inform the lower-level employees.

6.3.2. The Discretionary Access Control, or DAC

This model is the least restrictive model compared to the most restrictive MAC model. DAC allows an individual complete control over any objects they own along with the programs associated with those objects. This gives DAC two major weaknesses. First, it gives the end user complete control to set security level settings for other users which could result in users having higher privileges than they’re supposed to. Secondly, and worse, the permissions that the end-user has are inherited into other programs they execute. This means the end-user can execute malware without knowing it and the malware could take advantage of the potentially high-level privileges the end-user possesses.

6.3.3. Rule-Based Access Control

This model also with the acronym RBAC or RB-RBAC. Rule-Based Access Control will dynamically assign roles to users based on criteria defined by the custodian or system administrator. For example, if someone is only allowed access to files during certain hours of the day, Rule-Based Access Control would be the tool of choice. The additional “rules” of Rule-

Based Access Control requiring implementation may need to be programmed into the network by the custodian or system administrator in the form of code versus “checking the box.”

Chapter seven

7.1 Security planning

Security planning includes controls planned for future implementation, as well as resources planned for future use. Resources include personnel, contractors, equipment, software, and budgetary allocations. If you have security controls that are in the planning process, but will not be implemented until some point in the future, you should describe those controls in the section on security planning.

If you plan on hiring a security administrator or a security engineer, and have allocated budgetary funds for the next fiscal year to do that, indicate this intent. If you plan on implementing new intrusion detection systems, antivirus software, single sign-on systems, or anything that will remediate existing vulnerabilities, be sure to mention this. Security planning refers to security initiatives that will improve the security posture of your organization at some point in the future.

7.2 Risk analysis

Risk analysis is the process of identifying and analyzing potential issues that could negatively impact key business initiatives or projects. This process is done in order to help organizations avoid or mitigate those risks.

Performing a risk analysis includes considering the possibility of adverse events caused by either natural processes, like severe storms, earthquakes or floods, or adverse events caused by malicious or inadvertent human activities. An important part of risk analysis is identifying the potential for harm from these events, as well as the likelihood that they will occur.

Why is risk analysis important?

Enterprises and other organizations use risk analysis to:

- anticipate and reduce the effect of harmful results from adverse events;
- evaluate whether the potential risks of a project are balanced by its benefits to aid in the decision process when evaluating whether to move forward with the project;

- plan responses for technology or equipment failure or loss from adverse events, both natural and human-caused; and
- identify the impact of and prepare for changes in the enterprise environment, including the likelihood of new competitors entering the market or changes to government regulatory policy.

What are the benefits of risk analysis?

Organizations must understand the risks associated with the use of their information systems to effectively and efficiently protect their information assets. Risk analysis can help an organization improve its security in a number of ways. Depending on the type and extent of the risk analysis, organizations can use the results to help:

What is risk management and why it is important?

- identify, rate and compare the overall impact of risks to the organization, in terms of both financial and organizational impacts;
- identify gaps in security and determine the next steps to eliminate the weaknesses and strengthen security;
- enhance communication and decision-making processes as they relate to information security;
- improve security policies and procedures and develop cost-effective methods for implementing these information security policies and procedures;
- put security controls in place to mitigate the most important risks;
- increase employee awareness about security measures and risks by highlighting best practices during the risk analysis process; and
- understand the financial impacts of potential security risks.

Steps in risk analysis process

The risk analysis process usually follows these basic steps:

- 1) **Conduct a risk assessment survey:** This first step, getting input from management and department heads, is critical to the risk assessment process. The risk assessment survey is a way to begin documenting specific risks or threats within each department.
- 2) **Identify the risks:** The reason for performing risk assessment is to evaluate an IT system or other aspect of the organization and then ask: What are the risks to the software, hardware,

data and IT employees? What are the possible adverse events that could occur, such as human error, fire, flooding or earthquakes? What is the potential that the integrity of the system will be compromised or that it won't be available?

- 3) **Analyze the risks:** Once the risks are identified, the risk analysis process should determine the likelihood that each risk will occur, as well as the consequences linked to each risk and how they might affect the objectives of a project.
- 4) **Develop a risk management plan:** Based on an analysis of which assets are valuable and which threats will probably affect those assets negatively, the risk analysis should produce control recommendations that can be used to mitigate, transfer, accept or avoid the risk.
- 5) **Implement the risk management plan:** The ultimate goal of risk assessment is to implement measures to remove or reduce the risks. Starting with the highest-priority risk, resolve or at least mitigate each risk so it's no longer a threat.
- 6) **Monitor the risks:** The ongoing process of identifying, treating and managing risks should be an important part of any risk analysis process.

7.3 Security policies

A security policy is a type of document that states in writing how a company plans to protect its physical and information technology assets. Security policies are living documents that are continuously updated and changing as technologies, vulnerabilities and security requirements change. A company's security policy may include an acceptable use policy. These describe how the company plans to educate its employees about protecting the company's assets. They also include an explanation of how security measurements will be carried out and enforced and procedure for evaluating the effectiveness of the policy to ensure that necessary corrections are made.

A policy has to address areas of security such as the following:

- Physical and location security
- Creating a security policy document
- Reacting to a security exposure.

Importance of security policies

- To ensure the confidentiality, integrity and availability of data.
- To help minimize risk.
- To coordinate and enforce a security program across an organization.
- To communicate security measures to third parties and external auditors.
- To help with regulatory compliance.

7.4 Cyber security

Cyber security is the practice of protecting systems, networks, and programs from digital attacks. These cyberattacks are usually aimed at accessing, changing, or destroying sensitive information; extorting money from users; or interrupting normal business processes.

Implementing effective cyber security measures is particularly challenging today because there are more devices than people, and attackers are becoming more innovative.

A successful cyber security approach has multiple layers of protection spread across the computers, networks, programs, or data that one intends to keep safe. In an organization, the people, processes, and technology must all complement one another to create an effective defense from cyber attacks. A unified threat management system can automate integration across select Cisco Security products and accelerate key security operations functions: detection, investigation, and remediation.

Why is cyber-security important?

In today's connected world, everyone benefits from advanced cyber defense programs. At an individual level, a cyber-security attack can result in everything from identity theft, to extortion attempts, to the loss of important data like family photos. Everyone relies on critical infrastructure like power plants, hospitals, and financial service companies. Securing these and other organizations is essential to keeping our society functioning.

Everyone also benefits from the work of cyber-threat researchers, like the team of 250 threat researchers at Talos, who investigate new and emerging threats and cyber attack strategies. They reveal new vulnerabilities, educate the public on the importance of cyber-security, and strengthen open source tools. Their work makes the Internet safer for everyone.

Types of cyber-security threats

Phishing is the practice of sending fraudulent emails that resemble emails from reputable sources. The aim is to steal sensitive data like credit card numbers and login information. It's the most common type of cyber attack. You can help protect yourself through education or a technology solution that filters malicious emails.

Ransomware is a type of malicious software. It is designed to extort money by blocking access to files or the computer system until the ransom is paid. Paying the ransom does not guarantee that the files will be recovered or the system restored.

Malware is a type of software designed to gain unauthorized access or to cause damage to a computer.

Social engineering is a tactic that adversaries use to trick you into revealing sensitive information. They can solicit a monetary payment or gain access to your confidential data. Social engineering can be combined with any of the threats listed above to make you more likely to click on links, download malware, or trust a malicious source.

7.5 Ethics

What defines ethics in information security?

Ethics can be defined as a moral code by which a person lives. For corporations, ethics can also include the framework you develop for what is or isn't acceptable behavior within your organization.

In computer security, cyber-ethics is what separates security personnel from the hackers. It's the knowledge of right and wrong, and the ability to adhere to ethical principles while on the job.

Why is ethics significant to information security?

The data targeted in cyber attacks is often personal and sensitive. Loss of that sensitive data can be potentially devastating for your customers, and it's crucial that you have the full trust of the individuals you've hired to protect it. Cyber-security professionals have access to the sensitive personal data they were hired to protect. So it's imperative that employees in these fields have a strong sense of ethics and respect for the privacy of your customers.

The field of information technology also expands and shifts so frequently that a strong ethical core is necessary to navigate it. It's important that your staff can determine what's in the best interest of your customers and the company as a whole. Specific scenarios that your employees might confront can sometimes be impossible to foresee, so a strong ethical core can be the foundation that lets employees act in those best interests even in difficult, unpredictable circumstances.

What are the ethical issues in cyber-security?

Cyber-security professionals need to know the same tricks used by their black hat counterparts. This means that a programmer should know how to and therefore, be able to copy credit card data, violate intellectual property agreements, steal trade secrets, and infiltrate medical records. The safety of your customers' data is in their hands, and it's your responsibility to recruit info-sec staff who will not take advantage of their unique position within your company.

Cyber-security also has the potential to interrupt your regular business procedures. So-called ethical hacking and protective measures can cause inconveniences for your customers and other employees, and it's important to schedule cyber-security efforts in low-traffic periods. Some professionals may prefer to focus on the technical aspects of their job, but providing the service your customers require is as important as maintaining your security system.

Many companies focus only on the technical abilities of a candidate for hire, but it's not enough that your staff have knowledge of technology and hacking techniques. They must also demonstrate the ability to maintain their moral standards while processing customer data or handling other grey areas of data management and cyber-security.

What are the key principles in computer ethics?

The Association for Computing Machinery (ACM) has created a Code of Ethics and Professional Conduct for those who work in computer systems. This code includes:

1) General Ethical Principles: These ground rules detail honesty, respect for privacy issues and intellectual property rights, and refrain from discrimination and other potential forms of harm.

2) Professional Responsibilities: This portion of the code refers to a professional's responsibility to the field by performing the work to the best of his or her ability and maintaining a high level of competence. This category also mentions the increase of public awareness of their work and the ability to accept review when needed.

3) Professional Leadership Principles: Computer science professionals are asked to work towards the public good, improve working life for their colleagues, and encourage other members of the field to learn and grow.

These principles are merely suggestions, but they provide a good starting place for discussing ethics within the field.